

LINUX INTERGALÁCTICO: BASE DA
JORNADA JEDI

FIREWALL!!!



10

LISTA DE FIGURAS

Figura 1 – Topologia de referência.....	10
Figura 2 – Processo básico de filtragem de pacotes.....	11
Figura 3 – Sentido do fluxo.....	14
Figura 4 – Exemplo de tabela de rastreamento de conexões	16
Figura 5 – Cenário para testes	17
Figura 6 – Verificação e criação da REDE NAT	18
Figura 7 – Cenário de estudos	20
Figura 8 – Etapas básicas para construção do firewall com IPTables.	20
Figura 9 – Verificação das regras residentes em memória.	22
Figura 10 – Descarga de regras preexistentes.....	22
Figura 11 – Ajuste das permissões do arquivo.....	23
Figura 12 – Ajuste das políticas de acesso	24
Figura 13 – Envio de pacotes ICMP	24
Figura 14 – Bloqueio do <i>loopback</i> pelas políticas de acesso do firewall	25
Figura 15 – Desbloqueio do <i>loopback</i>	25
Figura 16 – Liberação do tráfego ICMP	27
Figura 17 – Restauração da troca de pacotes ICMP.....	28
Figura 18 – Aprimoramento das regras.....	29
Figura 19 – Liberação das requisições HTTP	30
Figura 20 – Ativação da análise <i>stateful</i>	31
Figura 21 – Exemplo de regra no IPTables para liberação do SSH	37
Figura 22 – Topologia de referência 2 – Acesso à <i>Internet</i>	38
Figura 23 - Operação SNAT	41
Figura 24 - Exemplo de uso do DNAT.....	42
Figura 25 - Esquema da tabela NAT	43
Figura 26 – Configuração da LAN – Firewall.....	44
Figura 27 – Configuração da WAN – <i>Firewall</i>	45
Figura 28 – Configuração dos endereços IP – VM <i>host</i>	47
Figura 29 – Mensagem de finalização do <i>script</i>	50
Figura 30 – Menu principal do firewall.....	50
Figura 31 – Teste de conectividade com o servidor	51
Figura 32 – Habilitando o encaminhamento de pacotes	51
Figura 33 – Conteúdo da tabela NAT	52
Figura 34 – Conteúdo da tabela FILTER.....	53
Figura 35 – Configuração do <i>Putty</i>	54
Figura 36 – Acesso remoto ao servidor.....	54
Figura 37 – Conteúdo da tabela de conexões.....	55
Figura 38 – Log da conexão SSH	55
Figura 39 – Opções <i>pfSense</i>	56
Figura 40 – Instalação do <i>pfSense</i>	58
Figura 41 – Topologia de referência 3 – <i>pfSense</i>	58
Figura 42 – Console do <i>pfSense</i>	59
Figura 43 – Interface gráfica de configuração	60
Figura 44 – <i>Dashboard</i> do <i>pfSense</i>	60
Figura 45 – Regras padrão – WAN	61
Figura 46 – Regras padrão – LAN.....	62
Figura 47 – Teste de navegação.....	63

Figura 48 – Opções do menu <i>Services</i>	64
Figura 49 – Serviço VPN	65
Figura 50 – Exemplos de pacotes adicionais	65

EMANIP

LISTA DE QUADROS

Quadro 1 – Protocolos de serviço	9
Quadro 2 – Tabela de conexões (<i>connection tracking table</i>)	34
Quadro 3 – Principais campos da Tabela de conexões do firewall	34
Quadro 4 – Listagem das regras residentes em memória.....	35
Quadro 5 – <i>Logs</i> parciais SSH e ICMP	36
Quadro 6 – Propriedades da VM <i>pfSense</i>	57

EXEMPLO

LISTA DE TABELAS

Tabela 1 – Sumarização das sub redes	12
Tabela 2 – Configurações das VMs	43

EMANIP

LISTA DE CÓDIGOS-FONTE

Código-fonte 1 – Íntegra do script do firewall	33
Código-fonte 2 – Configuração dos endereços IP – VM firewall	46
Código-fonte 3 – Script fw_nat	49

EMANIP

LISTA DE COMANDOS DE PROMPT DO SISTEMA OPERACIONAL

Comando de prompt 1 – Configuração da VM Metasploitable 2	18
Comando de prompt 2 – Liberação da porta 22	32
Comando de prompt 3 – Chain FORWARD	39
Comando de prompt 4 – Habilitação do encaminhamento de pacotes no kernel.....	39
Comando de prompt 5 – Configuração do SNAT	41
Comando de prompt 6 – Configuração do DNAT	42
Comando de prompt 7 – Configuração do endereço IP – VM server	45
Comando de prompt 8 – Configuração SNAT	52

SUMÁRIO

FIREWALL!!!	9
1 INTRODUÇÃO	9
2 FILTRAGEM DE PACOTES.....	11
2.1 Lógica geral da filtragem de pacotes.....	11
2.2 Supernet: 10.0.0.0/22	13
2.3 Considerações sobre as políticas de acesso	13
2.4 Considerações sobre os diferentes fluxos de pacotes no firewall	14
2.5 Considerações sobre os diferentes estados das conexões a analisar	15
3 CONHECENDO O IPTABLES.....	17
3.1 Cenário para estudo	17
4 HANDS ON	19
4.1 Considerações gerais para configuração do firewall local.....	20
4.2 Verificação de descarga de regras preexistentes.....	21
4.3 Configurando as políticas de acesso e liberando o <i>loopback do firewall</i>	23
4.4 Configurando regras específicas: pacotes ICMP	26
4.5 Configurando regras específicas: serviço HTTP	30
4.6 Configurando regras específicas: serviço SSH	32
4.7 Configurando regras específicas: logs de acessos	32
5 LOGS, TABELAS DE CONEXÕES E OUTROS	33
5.1 Elementos relevantes	33
5.1.1 Tabela de conexões	34
5.2 Listagem das regras (Tabela FILTER)	35
5.3 Logs de acesso SSH.....	35
6 ENCAMINHAMENTO DE PACOTES E NAT	37
6.1 A tabela NAT (<i>Network Address Translation</i>).....	39
7 HANDS ON 2 – COMPARTILHAMENTO DE CONEXÃO	43
7.1 Considerações sobre a configuração de cada VM	45
REFERÊNCIAS.....	66

FIREWALL!!!

1 INTRODUÇÃO

Certamente, o termo firewall não é novidade para ninguém de alguma forma relacionado à TI, normalmente, fazendo referência a um dispositivo destinado a filtrar e disciplinar o tráfego que entra e/ou sai de uma rede de acordo com as políticas de segurança da empresa.

Estas políticas são implementadas de duas maneiras diferentes e complementares entre si: a primeira é por adesão, promovida pela empresa por meio da conscientização e esclarecimento de seus colaboradores, em relação ao uso dos recursos da rede, como o uso da Internet, dentre outras ações.

Complementarmente, os equipamentos responsáveis por disciplinar e monitorar o uso desses recursos, especialmente os firewalls, serão configurados com as regras de acesso que imporão as determinações da política de segurança. Esses equipamentos analisam as características dos pacotes que chegam ou saem de sua(s) interface(s), executando o determinado pelas políticas de segurança.

Originalmente, os firewalls analisavam os pacotes com base nos respectivos endereços de origem e de destino, e quando necessário, também com base no serviço requisitado representado pelo protocolo da camada de transporte (L4) mais a porta utilizada, conforme exemplificado no quadro abaixo:

Protocolo L4	Porta	Serviço	Descrição
TCP	21	FTP	Troca de arquivos na <i>web</i>
TCP	22	SSH	Acesso remoto seguro
TCP	23	Telnet	Acesso remoto (inseguro)
TCP	53	DNS	Troca de zona
UDP			Resolução de nomes (lookup)
TCP	80	HTTP	Navegação <i>web</i>
UDP	123	NTP	Sincronização de relógios

Quadro 1 – Protocolos de serviço
Fonte: Elaborado pelo autor (2018)

Entretanto, com a evolução da Internet, novas funcionalidades tiveram de ser agregadas ao firewall original a fim de possibilitar-lhe a detecção e mitigação das novas ameaças que surgiam, passando, então, a ser chamado de UTM (Unified Threat Management).

No cenário representado na figura abaixo, pode-se observar o uso de um UTM segregando a rede confiável (LAN) da rede não confiável (Internet). Assim sendo, as regras configuradas servirão para disciplinar o tráfego entre essas duas redes.

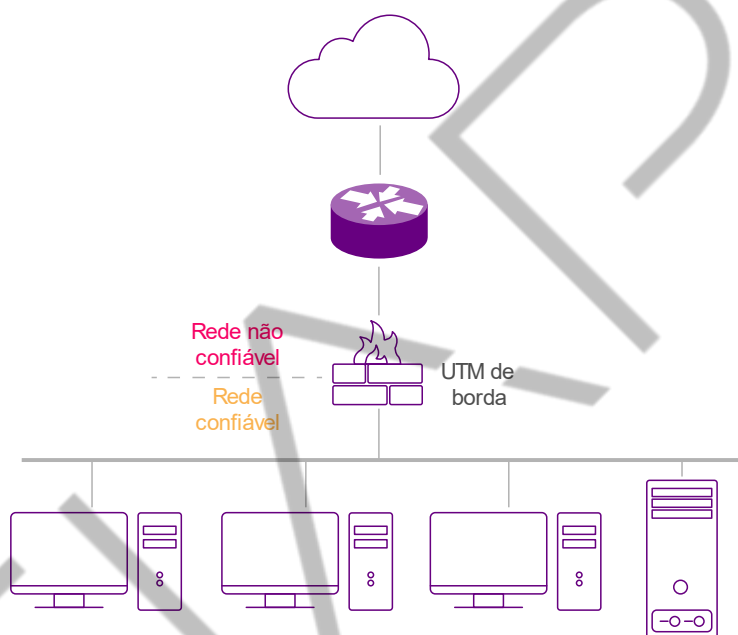


Figura 1 – Topologia de referência
Fonte: Elaborado pelo autor (2018)

Considere agora que alguma das estações de trabalho indicadas na figura venha a ser infectada por um worm, o que a levaria a propagação do código malicioso pela rede local na tentativa de infectar outras estações de trabalho, ou mesmo servidores, vulneráveis (movimentação lateral).

Outra possibilidade seria um usuário mal-intencionado atacar outros *hosts* na rede, por exemplo, por meio de icmp flood. Dentre outras possibilidades, essas duas permitem observar que o UTM de borda é incapaz de proteger os *hosts* residentes na rede local em tais situações, ou mesmo em outras em que o tráfego malicioso não atravessa suas *interfaces* fazendo-se necessário, portanto, que esses *hosts* possuam filtros de pacotes (firewalls) locais que ajudem a compor uma solução adequada à proteção do *host*.

Vale destacar que uma das opções mais eficientes recai sobre a configuração dos firewalls que integram as soluções de antivírus mais avançadas. Entretanto, a correta configuração da filtragem de pacotes requer considerável conhecimento técnico a fim de evitar que falsos positivos indevidamente bloqueiem tráfego legítimo e, ainda, que falsos negativos permitam tráfego malicioso.

2 FILTRAGEM DE PACOTES

A correta configuração da filtragem de pacotes depende de diversos fatores técnicos, os quais independem das determinações das políticas de segurança. Antes de tudo, é necessário saber a lógica utilizada por ela.

2.1 Lógica geral da filtragem de pacotes

A filtragem de pacotes segue uma lógica geral bastante simples, a qual deve ser claramente entendida. A figura a seguir representa o processo básico adotado pelos filtros de pacotes.

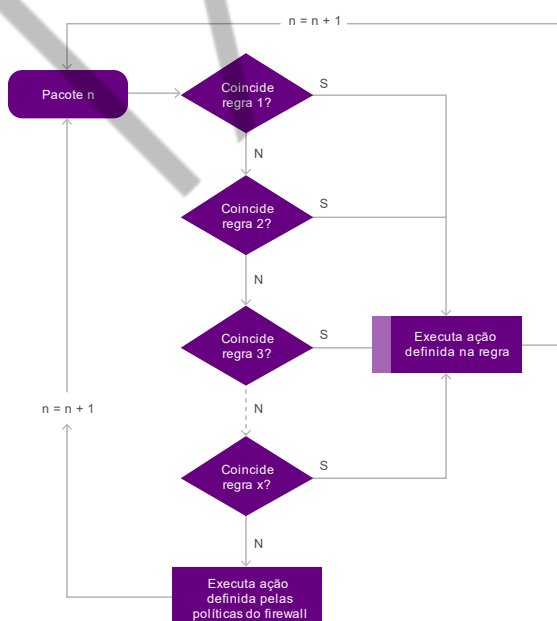


Figura 2 – Processo básico de filtragem de pacotes
Fonte: Elaborado pelo autor (2018)

Na figura “Processo básico de filtragem de pacotes” é possível observar que cada pacote que chega ao firewall é individualmente analisado. Logo, as regras de filtragem deverão ser bem planejadas, também a fim de otimizar o uso da memória (RAM), local onde as regras permanecerão residentes, ao invés do disco rígido; uma vez que este poderia causar muita latência no processo.

Uma forma de otimização das regras consiste da sumarização das diversas redes de origem e/ou de destino dos pacotes que deverão ser filtrados, ao invés da criação de uma regra para cada uma dessas redes. Admita-se que uma regra deverá permitir que apenas os hosts das vlans 10, 20, 30 e 40 acessem um servidor.

Ao invés de escrever uma regra para cada uma das sub redes dessas vlans, pode-se sumariá-las em uma supernet como demonstrado na tabela a seguir e, então, escrever uma única regra.

- VLAN 10: 10.0.0.0/24
- VLAN 20: 10.0.1.0/24
- VLAN 30: 10.0.2.0/24
- VLAN 40: 10.0.3.0/24

	REDES						HOSTS	
	128	64	32	16	8	4	2	1
10.0.0.0	0	0	0	0	0	0	0	0
10.0.1.0	0	0	0	0	0	0	0	1
10.0.2.0	0	0	0	0	0	0	1	0
10.0.3.0	0	0	0	0	0	0	1	1
AND	0	0	0	0	0	0	0	0

Tabela 1 – Sumarização das sub redes
Fonte: Elaborado pelo autor (2018)

2.2 Supernet: 10.0.0.0/22

No filtro, o pacote será comparado ao especificado pela primeira regra configurada. Se as características do pacote coincidirem com o especificado pela regra, a ação definida por ela será executada, caso contrário, o pacote será comparado à regra seguinte, e assim sucessivamente até atingir a última regra configurada. Caso as características do pacote não coincidam com nenhuma das regras específicas, serão então aplicadas as políticas de acesso configuradas no firewall e o processo será reiniciado com o pacote seguinte.

2.3 Considerações sobre as políticas de acesso

É bastante comum profissionais que, não necessariamente pertencem à área de segurança, mas precisam configurar um sistema de filtragem de pacotes, perguntarem ao cliente: “O que eu devo bloquear?”

Devemos lembrar que existem dois dos principais pilares da segurança da informação (CID), que são: (I) a CONFIDENCIALIDADE da informação significa que ela deverá ser revelada ou estar acessível, unicamente aos que tiverem autorização para tal; (II) e a DISPONIBILIDADE é a propriedade da informação de estar disponível e acessível quando necessário, aos que tiverem a devida autorização para tal. Conclui-se, então, que a segurança da informação é restritiva por padrão e, assim sendo, a pergunta correta seria: “O que eu devo liberar?”. Parte-se, portanto, do pressuposto que por padrão tudo deverá ser bloqueado, liberando-se o estritamente determinado pelas políticas de segurança, prática conhecida como whitelisting.

Em termos práticos, esse tipo de implementação pode ser bem mais trabalhoso do que pode aparentar pois, se dentre inúmeras outras possibilidades, um usuário precisar acessar algum *website* não contemplado pelas políticas de segurança, ele necessitará de permissão especial para isso, o que poderá atrapalhar seu fluxo de trabalho.

Caso a empresa venha a adotar a prática de blacklisting, ou seja, bloqueando estritamente pontos específicos e liberando o acesso ao restante, situações imprevistas poderão impactar fortemente o desempenho dos sistemas de proteção, prejudicando sua eficiência e confiabilidade.

Assim sendo, de maneira geral, pode-se dizer que a opção mais adequada para configuração das políticas padrão de um firewall será torná-lo totalmente restritivo, descartando todos os pacotes que não tenham correspondência com nenhuma regra específica.

2.4 Considerações sobre os diferentes fluxos de pacotes no firewall

A criação das regras para filtragem deve observar atentamente o sentido dos fluxos de pacotes que atravessam a(s) *interface(s)* do firewall.

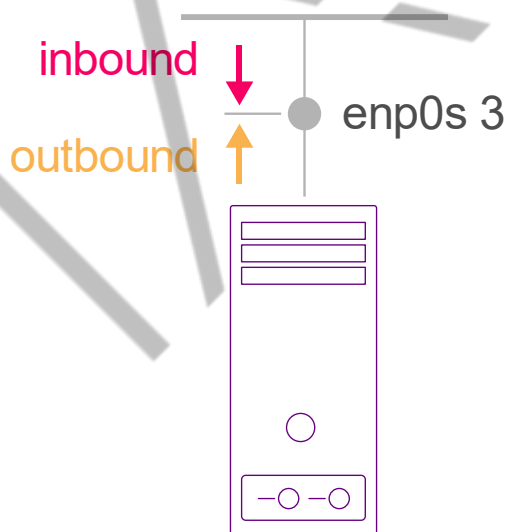


Figura 3 – Sentido do fluxo
Fonte: Elaborado pelo autor (2018)

Na figura “Sentido do fluxo”, observa-se que a *interface* a ser monitorada pelo firewall deve ser tomada como referência para classificação do tráfego como entrante (*inbound*) ou saiente (*outbound*), e não a *interface* do *host* que envia as requisições ao ativo monitorado.

Vale destacar ainda que, até algum tempo atrás, alguns administradores de firewall consideravam que o tráfego que deixava o equipamento (também muitas vezes referenciado como caixa) era seguro. De maneira geral, atualmente, essa não é uma boa ideia, pois além da possibilidade de movimentação lateral, boa parte dos ataques não são mais iniciados de fora para dentro da rede, mas sim, de dentro para fora.

Diante desse contexto, significa dizer que, além do risco de um worm contaminar os demais hosts da rede (movimentação lateral), há ainda o grande risco de um usuário permitir que um malware entre em seu host via phishing, abrindo um backdoor que não será impedido pelo firewall local (interno do host) caso a saída de pacotes deste host seja indiscriminadamente permitida, em outros termos, um ataque de dentro para fora.

2.5 Considerações sobre os diferentes estados das conexões a analisar

Outro aspecto relevante a ser considerado quando da construção das regras de filtragem, remete aos diferentes estados que as conexões com o *host* monitorado poderão assumir. Nos firewalls de primeira geração, a filtragem de pacotes priorizava a inspeção dos dados de camada 3, isto é, endereços de origem e destino do pacote.

Embora os firewalls dessa geração também inspecionassem o tráfego pelas portas de serviços, ainda não monitoravam os estados das conexões, em outras palavras, eram *STATELESS*. Mesmo que já nessa época o principal protocolo utilizado pela camada de transporte fosse o TCP (protocolo orientado a conexão). Isso foi alterado na segunda geração dos firewalls, quando estes passaram a filtrar o tráfego monitorado também com base no estado das conexões (firewalls *stateful*).

Os quatro estados considerados para uma conexão são:

- **NEW:** significa que o pacote iniciou uma nova conexão, ou que está de alguma outra forma associado a uma conexão na qual ainda não se tenha observado pacotes em ambas as direções (entrando e saindo das interfaces).

- **ESTABLISHED:** quando o pacote faz parte de uma conexão já previamente estabelecida, por exemplo, a resposta de um servidor a uma solicitação do cliente.
- **RELATED:** quando o pacote está iniciando uma nova conexão, porém, relacionada a outra conexão já existente. Por exemplo, a conexão iniciada pelo FTP-DATA para transmissão dos arquivos solicitados pelo usuário (essa conexão será permitida somente se estiver relacionada a uma conexão FTP-CONTROL previamente estabelecida).
- **INVALID:** o pacote não foi identificado em nenhuma conexão existente na tabela de rastreamento de conexões (*connection tracking table*).

A tabela rastreamento de conexões é aquela na qual são registradas as informações de todas as conexões ativas no firewall. A figura abaixo exemplifica a tabela de rastreamento de conexões do pfSense, tradicional UTM em *software livre*.

iptables connection tracking

Legend: LAN INTERNET DMZ Wireless IPFire VPN OpenVPN

Source IP: Port Dest. IP: Port Protocol: Connection Status Expires (Secs)

All All Update

192.168.180.214	54605	192.168.180.1	444 (SNPP)	tcp	ESTABLISHED	119:59:59
192.168.180.214	53993	217.253.242.60	444 (SNPP)	tcp	ESTABLISHED	119:59:59
89.245.253.172	58390	64.12.28.96	443 (HTTPS)	tcp	ESTABLISHED	119:59:57
192.168.181.211	46000	192.168.180.1	9091	tcp	ESTABLISHED	119:59:57
192.168.181.211	37959	192.168.180.1	9091	tcp	ESTABLISHED	119:59:57
89.245.253.172	55066	205.188.254.89	443 (HTTPS)	tcp	ESTABLISHED	119:59:57
89.245.253.172	39960	205.188.246.129	443 (HTTPS)	tcp	ESTABLISHED	119:59:57
192.168.180.214	33894	192.168.180.1	800 (MDBS_DAEMON)	tcp	ESTABLISHED	119:59:56
192.168.180.214	33891	192.168.180.1	800 (MDBS_DAEMON)	tcp	ESTABLISHED	119:59:56
192.168.180.214	48850	217.253.242.60	444 (SNPP)	tcp	ESTABLISHED	119:59:56
192.168.180.214	33892	192.168.180.1	800 (MDBS_DAEMON)	tcp	ESTABLISHED	119:59:56
192.168.180.214	50409	208.68.163.220	5222	tcp	ESTABLISHED	119:59:54
192.168.180.214	50883	192.168.180.1	139 (NETBIOS-SSN)	tcp	ESTABLISHED	119:59:53
192.168.180.214	56453	192.168.180.1	8765	tcp	ESTABLISHED	119:59:48
192.168.180.214	41298	172.28.1.162	22 (SSH)	tcp	ESTABLISHED	119:59:47
192.168.181.211	33688	192.168.181.1	445 (MICROSOFT-DS)	tcp	ESTABLISHED	119:59:47
192.168.181.211	57410	192.168.181.1	8765	tcp	ESTABLISHED	119:59:46

Figura 4 – Exemplo de tabela de rastreamento de conexões
Fonte: Fórum pfSense (2018)

3 CONHECENDO O IPTABLES

O IPTables é um dos projetos mais populares do *netfilter.org*. Consiste em uma aplicação em *userspace* destinada a administradores de sistemas, para configuração das regras para filtragem de pacotes no *kernel Linux 2.4.x* e posteriores, em linha de comando. As principais características do IPTables podem ser resumidas em:

- Listar o conjunto de regras para filtragem de pacotes.
- Gerenciar o conjunto de regras para filtragem de pacotes.
- Listar/zerar os contadores das regras de filtragem.

Aplicações avançadas do IPTables incluem ainda a construção de *clusters* de firewalls de alta disponibilidade, implementação de NAT para *proxies* transparentes e QoS, dentre outras.

3.1 Cenário para estudo

O cenário para implementação prática e estudo do firewall local consistirá em três máquinas virtuais: VMs Debian1 e Debian2 (clientes), e VM Metasploitable2 (servidor). O referido cenário é ilustrado abaixo.

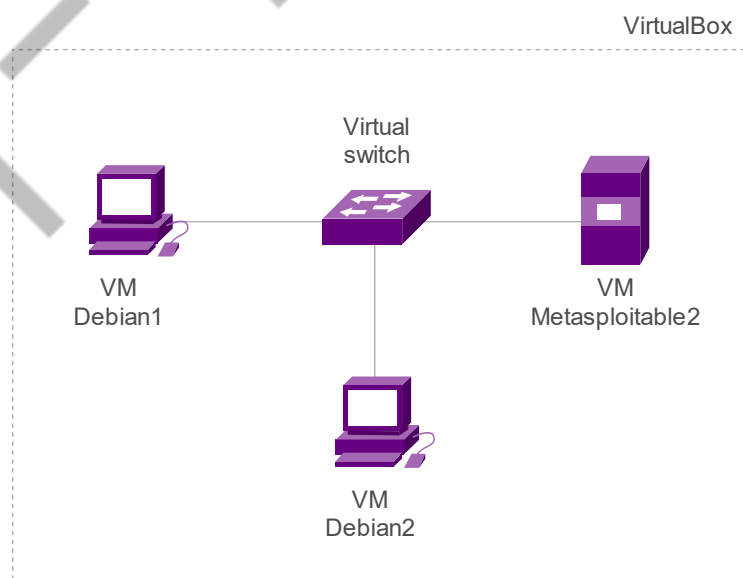


Figura 5 – Cenário para testes
Fonte: Elaborado pelo autor (2018)

Antes de iniciar, deve-se certificar de que o tipo de rede esteja configurado para REDE NAT. Para esse fim, no menu principal do VirtualBox, clicar em ARQUIVO > PREFERÊNCIAS > REDE (figura a seguir).

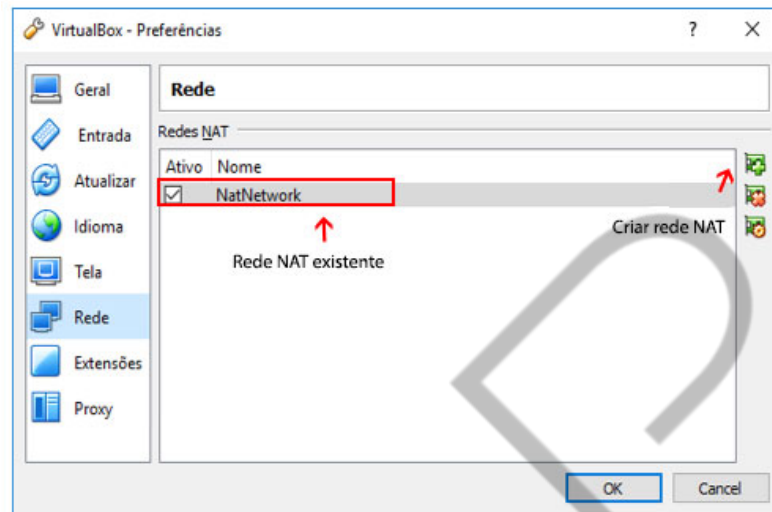


Figura 6 – Verificação e criação da REDE NAT
Fonte: Elaborado pelo autor (2018)

O tipo de teclado originalmente definido na VM Metasploitable também deverá ser reconfigurado de acordo com o teclado empregado pelo usuário (geralmente ABNT2). Deve ser utilizado o comando em destaque, para esse propósito, sendo que, eventualmente, algumas tentativas precisarão ser feitas antes de encontrar a configuração desejada.

```
msfadmin@metasploitable:~$ sudo dpkg-reconfigure console-setup
```

Comando de prompt 1 – Configuração da VM Metasploitable 2
Fonte: Elaborado pelo autor (2018)

É importante destacar que a VM Metasploitable2 poderá apresentar problemas de inicialização após o ajuste no teclado.

Sempre tire *snapshot* do estado dessa VM antes de fazer, **qualquer alteração**, assim, se algum problema ocorrer, ela poderá ser restaurada ao estado anterior à ocorrência.

Configurado o teclado, os endereços IP atribuídos a cada um dos *hosts* deverá ser verificado, e a conectividade entre eles testada por meio do aplicativo *ping*.

Estando tudo certo, a configuração do firewall local do *host* Metasploitable 2 poderá ser iniciada. No cenário, foi atribuído ao *host* Metasploitable2 o endereço IP 10.0.2.21, ao *host* Debian1 o endereço IP 10.0.2.22 e ao *host* Debian2 o endereço 10.0.2.23. Esses endereços IP poderão variar e, assim sendo, deve-se sempre utilizar os endereços efetivamente atribuídos aos *hosts* do ambiente de testes.

4 HANDS ON

Tome-se como referência para configuração do firewall da VM Metasploitable2, ser este um servidor HTTP disponível apenas para a rede local, constituindo uma espécie de INTRANET simples, a partir da qual os usuários poderão consultar as políticas de segurança da empresa, ler avisos gerais e boletins internos dentre outras informações devidamente classificadas pela política de segurança como públicas. Com base nisso, adotam-se como diretrizes iniciais para configuração do firewall local:

- O acesso à INTRANET deverá ser feito via HTTP.
- A manutenção do servidor deverá ser feita remotamente, por meio de protocolo de acesso seguro (SSH), sendo aceitas conexões originadas, exclusivamente, a partir da estação de trabalho do administrador (Debian1).
- As estações da rede local (LAN) poderão enviar pacotes ICMP ao servidor HTTP (Metasploitable2) a fim de verificar a conectividade com este.
- Todos os acessos e pacotes ICMP enviados ao servidor deverão ser devidamente logados.

A figura abaixo ilustra o cenário considerado, com as devidas informações complementares.

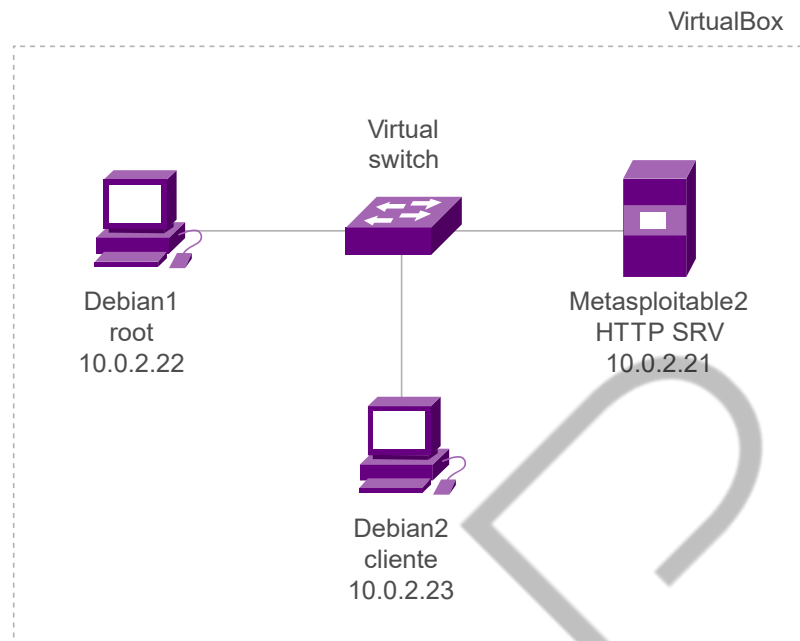


Figura 7 – Cenário de estudos
Fonte: Elaborado pelo autor (2018)

4.1 Considerações gerais para configuração do firewall local

A construção do firewall seguirá as etapas ilustradas a seguir:

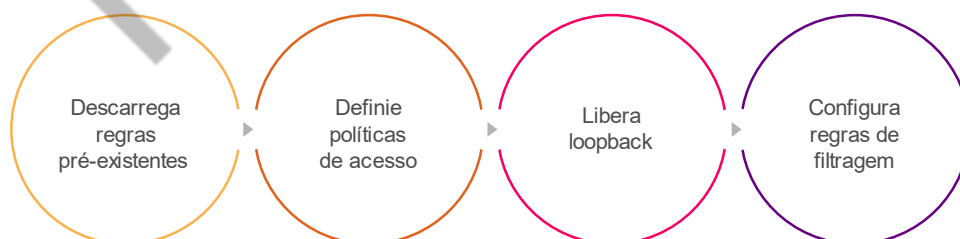


Figura 8 – Etapas básicas para construção do firewall com IPTables.
Fonte: Elaborado pelo autor (2018)

É importante que regras eventualmente preexistentes sejam descarregadas antes que novas sejam configuradas, a fim de assegurar que as regras residentes em memória sejam fiéis ao desejado por quem configura o equipamento. Disso vêm dois importantes pontos:

- Como todas as regras ficam residentes em memória, a fim de garantir a performance do firewall, é importante que elas sejam concebidas de forma eficiente. Conforme mencionado anteriormete , se os *hosts* de quatro diferentes sub-redes da LAN (VLANs) devem acessar o servidor, ao invés de criar uma regra para cada uma dessas sub-redes, sempre que viável, deve-se sumariá-las criando uma única supernet, cujo tráfego possa ser monitorado por uma única regra de acesso.
- Toda vez que alguma(s) das regras do firewall for(em) modificada(s) (acrescidas, excluídas ou alteradas), todas elas deverão ser recarregadas para a memória.

Portanto, uma das melhores maneiras de configurar o IPTables de forma nativa, ou seja, em linha de comando, é por meio de scripts. Isso feito, devem ser definidas as políticas de acesso a serem configuradas no firewall. Caso a política de segurança da empresa não indique nada em contrário, sugere-se que as políticas de acesso do firewall sejam totalmente restritivas, no caso, todo tráfego que entrar ou sair do equipamento monitorado deverá ser descartado.

Entretanto, isso terá como consequência imediata o descarte também dos pacotes enviados ao *loopback*, o que poderá trazer problemas de conectividade – dentre outros, necessitando assim ser adequadamente tratado. Após tratados esses aspectos básicos, comuns a praticamente qualquer implementação, as regras específicas poderão ser, então, configuradas.

4.2 Verificação de descarga de regras preexistentes

Para se verificar as regras preexistentes no *host* Metasploitable2, basta solicitar ao *IPTables* que liste as regras residentes em memória, lembrando que, para isso, credenciais de usuários com privilégios administrativos deverão ser utilizadas.

Como o *Metasploitable* não habilita a conta do *root*, o comando *sudo* será utilizado para escalar os privilégios do usuário *msfadmin*.

```
msfadmin@metasploitable:~$ sudo iptables -L
Chain INPUT (policy ACCEPT)
target     prot opt source                destination

Chain FORWARD (policy ACCEPT)
target     prot opt source                destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source                destination
msfadmin@metasploitable:~$ _
```

Figura 9 – Verificação das regras residentes em memória.
Fonte: Elaborada pelo autor (2018)

O comando *iptables -L* lista as regras residentes em memória, associadas a cada um dos fluxos de dados (*CHAINS*) contemplados pela Tabela *FILTER*, tabela utilizada pelo *IPTables* para gerenciar o tráfego que entra (*INPUT*), sai (*OUTPUT*) e atravessa (*FORWARD*) o firewall pela(s) interface(s) monitorada(s). Como a VM *Metasploitable2* possui apenas uma *interface* “física”, ela sempre será tomada como referência pelo *IPTables*. Pela figura “Verificação das regras residentes em memória” é possível observar que ainda não há qualquer filtragem aplicada ao tráfego que entra, sai ou atravessa o firewall pela *interface* monitorada. O *script* para configuração do firewall será iniciado criando-se no VI, ou qualquer outro editor de textos do *Linux*, o arquivo *firewall.sh* contendo as instruções ilustradas na figura abaixo.

```
1 #!/bin/bash
2 clear
3 #descarrega regras pre existentes
4 iptables -F
5 iptables -X
```

Figura 10 – Descarga de regras preexistentes
Fonte: Elaborado pelo autor (2018)

A linha 1 no código define o shell a ser utilizado pelo *Linux* para execução do *script* de configuração do firewall, devendo-se atentar à sequência de caracteres que inicia a linha: *#!* - denominada shebang, especificamente destinada a essa função. Na linha 2 a tela será apagada, tendo-se na linha 3, a descrição da função das linhas 4 e 5. Ambas as referidas linhas descarregam regras preexistentes na memória, entretanto, na linha 4 são descarregadas somente regras gerais e, eventualmente, pré-configuradas pela distribuição (-F), já na linha 5, regras específicas, criadas pelo usuário (-X). Finalizada a digitação no arquivo, ele deverá ser gravado, e suas permissões ajustadas a fim de que se torne executável conforme apresentado abaixo.

```
msfadmin@metasploitable:~$ ls -l firewall.sh
-rw-r--r-- 1 msfadmin msfadmin 76 2018-05-13 12:20 firewall.sh
msfadmin@metasploitable:~$ chmod u+x firewall.sh
msfadmin@metasploitable:~$ ls -l firewall.sh
-rwxr--r-- 1 msfadmin msfadmin 76 2018-05-13 12:20 firewall.sh
msfadmin@metasploitable:~$ _
```

Figura 11 – Ajuste das permissões do arquivo
Fonte: Elaborado pelo autor (2018)

Deverá ser atribuída a permissão de execução do *script* ao usuário ao qual pertence, no caso, o usuário *msfadmin*. Basta utilizar o comando *chmod* conforme ilustrado na Figura “Ajuste das permissões do arquivo”. O *script* será executado ao digitar: *./firewall.sh*. À primeira vista, pode-se ter a impressão de que nada aconteceu, entretanto, se nenhum erro foi reportado, eventuais regras preexistentes foram descarregadas.

4.3 Configurando as políticas de acesso e liberando o *loopback* do firewall

Conforme apontado anteriormente, as políticas de acesso atuais do firewall não impõem restrições ao tráfego que adentra o *host* (Chain INPUT), que deixa o *host* (Chain OUTPUT), e nem que o atravessa (Chain Forward) pela interface monitorada. Assim sendo, as novas linhas ilustradas pela figura que segue, deverão ser adicionadas ao *script*.

```
1 #!/bin/bash
2 clear
3 #descarrega regras pre existentes
4 iptables -F
5 iptables -X
6 #
7 #define as politicas de acesso do firewall
8 iptables -P INPUT DROP
9 iptables -P OUTPUT DROP
10 iptables -P FORWARD DROP
```

Figura 12 – Ajuste das políticas de acesso
Fonte: Elaborado pelo autor (2018)

Na linha 8, solicita-se ao iptables que adote como política (-P) o descarte (DROP) dos pacotes que adentrem o firewall (INPUT) pela interface monitorada, reforçando-se aqui, que as políticas só serão aplicadas aos pacotes cujas características não sejam previstas por nenhuma regra específica. Analogamente, nas linhas 9 e 10 são criadas as políticas aplicáveis, respectivamente, ao tráfego que deixa e que atravessa o firewall pela interface monitorada. A figura abaixo ilustra a resposta do firewall aos pacotes ICMP enviados pelo host Debian1.

```
root@debian01:~# ping 10.0.2.21
PING 10.0.2.21 (10.0.2.21) 56(84) bytes of data.
64 bytes from 10.0.2.21: icmp_seq=1 ttl=64 time=0.245 ms
64 bytes from 10.0.2.21: icmp_seq=2 ttl=64 time=0.606 ms
64 bytes from 10.0.2.21: icmp_seq=3 ttl=64 time=0.691 ms
64 bytes from 10.0.2.21: icmp_seq=4 ttl=64 time=0.670 ms
█
```

Figura 13 – Envio de pacotes ICMP
Fonte: Elaborada pelo autor (2018)

Como pode ser observado pela figura “Envio de pacotes ICMP”, ao redefinir as políticas de acesso do firewall como DROP, os pacotes enviados ao *host* passaram a ser descartados. Entretanto, o descarte dos pacotes pode ser feito de duas formas distintas pelo IPTables:

- DROP: nesta opção, os pacotes são descartados pelo firewall sem que nenhuma notificação seja enviada ao seu *host* de origem, o que faz com que ele permaneça aguardando pela resposta. Essa forma de descarte favorece a segurança, na medida em que inibe ataques por *flood*, impede que o *host* protegido pelo firewall venha a ser inundado por pacotes, mitigando, assim, ataques de negação de serviço (DoS), distribuídos ou não.
- REJECT: nesta opção, o *host* de origem dos pacotes é notificado do descarte, o que faz com que o uso dessa opção seja restrito, geralmente, a testes de regras e diagnósticos, devendo ser evitado em produção.

Ao serem carregadas, as novas políticas de acesso do firewall, tornam também o *loopback* inacessível, o que deve ser prontamente tratado a fim de evitar os potenciais problemas decorrentes dessa situação.

```
msfadmin@metasploitable:~$ ping 127.0.0.1
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
ping: sendmsg: Operation not permitted
ping: sendmsg: Operation not permitted
ping: sendmsg: Operation not permitted

--- 127.0.0.1 ping statistics ---
3 packets transmitted, 0 received, 100% packet loss, time 2009ms
msfadmin@metasploitable:~$ _
```

Figura 14 – Bloqueio do *loopback* pelas políticas de acesso do firewall
Fonte: Elaborado pelo autor (2018)

A figura acima ilustra a mensagem de erro retornada quando da tentativa de envio de pacotes ICMP à interface *loopback* do servidor. A fim de desbloquear o acesso a ela, duas novas regras são adicionadas ao script.

```
1 #!/bin/bash
2 clear
3 #descarrega regras pre existentes
4 iptables -F
5 iptables -X
6 #
7 #define as politicas de acesso do firewall
8 iptables -P INPUT DROP
9 iptables -P OUTPUT DROP
10 iptables -P FORWARD DROP
11 #libera acesso ao loopback
12 iptables -A INPUT -i lo -j ACCEPT
13 iptables -A OUTPUT -o lo -j ACCEPT
```

Figura 15 – Desbloqueio do *loopback*
Fonte: Elaborado pelo autor (2018)

Na linha 12, da figura acima, tem-se: **iptables -A INPUT -i lo -j ACCEPT**, a qual solicita ao *IPTables* que adicione (-A) uma nova regra que monitore o tráfego de entrada (*INPUT*) na *interface* (-i) de *loopback* (lo), liberando sua entrada (-j *ACCEPT*). A opção -j (*jump target*) especifica a ação a ser executada pela regra caso as características do pacote analisado coincidam com o especificado por esta regra, no caso, o tráfego deverá ser liberado (*ACCEPT*).

É importante observar que o uso da opção -A para adicionar uma nova regra fará com que ela seja colocada no final da lista. A posição das regras é altamente relevante em filtros de pacotes, uma vez que se colocadas em ordem inadequada, poderão produzir efeitos adversos.

Regras mais específicas deverão anteceder regras mais amplas. Por exemplo, se necessário bloquear um *host* da rede, seu endereço IP deverá ser bloqueado por uma regra, e na sequência, uma nova regra deverá liberar a rede inteira onde ele reside.

Logo, em caso de necessidade de inserção de uma nova regra em posição específica da pilha, deve-se usar a opção -I (*insert*) em vez de -A (*append*). Analogamente, a regra na linha 13 libera o tráfego de saída da *interface loopback* restaurando, assim, sua operação normal. Essa regra se faz necessária pois a política que supervisiona o tráfego de saída da *interface* monitorada (no caso, o *loopback*) determina seu descarte.

4.4 Configurando regras específicas: pacotes ICMP

Restaurado o funcionamento normal do *loopback*, é chegado o momento de se configurarem as regras específicas que constituirão o *firewall*, iniciando-se pelo monitoramento do tráfego ICMP.

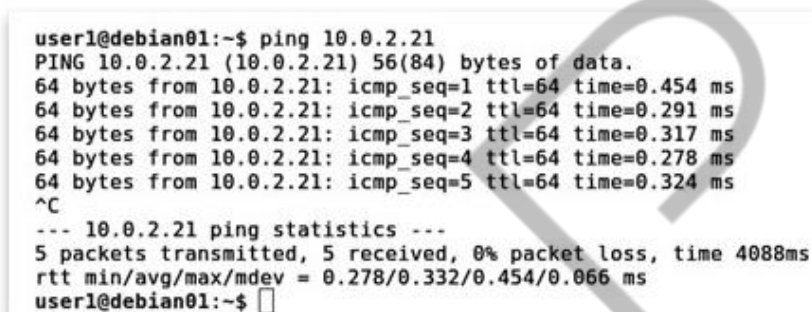
Embora alguns acreditem que esse tráfego não deva ser liberado, na prática, a impossibilidade de verificação da conectividade com o servidor (via ICMP) poderá trazer inconveniências desnecessárias. Algumas aplicações poderão usar pacotes ICMP para verificar se o servidor está *online* antes de tentar se conectar ao serviço desejado. Em situações como essa, o bloqueio indiscriminado do tráfego ICMP poderá criar dificuldades desnecessariamente. Geralmente, essas pessoas temem que um ataque de negação de serviço venha a ser deflagrado contra um servidor por meio de pacotes ICMP.

Todavia, quando são configurados corretamente, os filtros de pacotes conseguem diferenciar entre o uso adequado desses pacotes e um ataque, não havendo, portanto, razão para essa preocupação. Assim sendo, a liberação da troca de pacotes ICMP com os servidores da rede poderá ser efetivada, não havendo, entretanto, razão para permitir a troca de pacotes ICMP entre os demais *hosts* da rede. As linhas 17 e 18 da figura abaixo exemplificam regras para liberação do tráfego ICMP.

```
1 #!/bin/bash
2 clear
3 #descarrega regras pre existentes
4 iptables -F
5 iptables -X
6 #
7 #define as politicas de acesso firewall
8 iptables -P INPUT DROP
9 iptables -P OUTPUT DROP
10 iptables -P FORWARD DROP
11 #
12 #libera acesso ao loopback
13 iptables -A INPUT -i lo -j ACCEPT
14 iptables -A OUTPUT -o lo -j ACCEPT
15 #
16 #libera trafego icmp
17 iptables -A INPUT -p icmp -j ACCEPT
18 iptables -A OUTPUT -p icmp -j ACCEPT
```

Figura 16 – Liberação do tráfego ICMP
Fonte: Elaborado pelo autor (2018)

Na linha 17 da figura acima, é solicitado ao IPTables que adicione uma nova regra que monitore o tráfego entrante pela *interface* monitorada, liberando a entrada (-j *ACCEPT*) dos pacotes do protocolo (-p) ICMP. Analogamente, a linha 18 introduz no *firewall* a regra complementar, liberando a saída dos referidos pacotes. A figura a seguir – Restauração da troca de pacotes ICMP – ilustra a volta da troca de pacotes ICMP entre a estação *Debian1* e o servidor *Metasploitable* após o *firewall* ser recarregado com as novas regras.



```
user1@debian01:~$ ping 10.0.2.21
PING 10.0.2.21 (10.0.2.21) 56(84) bytes of data.
64 bytes from 10.0.2.21: icmp_seq=1 ttl=64 time=0.454 ms
64 bytes from 10.0.2.21: icmp_seq=2 ttl=64 time=0.291 ms
64 bytes from 10.0.2.21: icmp_seq=3 ttl=64 time=0.317 ms
64 bytes from 10.0.2.21: icmp_seq=4 ttl=64 time=0.278 ms
64 bytes from 10.0.2.21: icmp_seq=5 ttl=64 time=0.324 ms
^C
--- 10.0.2.21 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4088ms
rtt min/avg/max/mdev = 0.278/0.332/0.454/0.066 ms
user1@debian01:~$
```

Figura 17 – Restauração da troca de pacotes ICMP
Fonte: Elaborado pelo autor (2018)

Entretanto, deve ser observado que, embora as novas regras tenham produzido o resultado esperado, sua estruturação deve ser melhorada a fim de tornar-se devidamente granular:

- Certamente ocorrerão casos em que o host a ser supervisionado pelo *firewall* terá mais de uma *interface*. Sendo assim, o servidor deverá aceitar pacotes ICMP provenientes de todas elas?
- O servidor deverá aceitar requisições provenientes de toda e qualquer rede que possa alcançá-lo?
- O servidor deverá aceitar qualquer tipo de pacote ICMP?

Por esses simples questionamentos, observa-se que não basta que o *firewall* “funcione”, mas que seja granular e preciso. Logo, respondendo-se ao questionamento formulado, pode-se dizer que:

- Não, o *firewall* deverá aceitar pacotes apenas da(s) interface(s) especificada(s), no caso: *eth0*.
- Não, apenas das redes especificadas.

- Não, basicamente ele deverá aceitar apenas pacotes ICMP tipo *echo reply* e *echo request*.

Logo, com base no exposto, essas regras poderiam ser otimizadas conforme ilustrado a seguir:

```
1 #!/bin/bash
2 clear
3 #descarrega regras pre existentes
4 iptables -F
5 iptables -X
6 #
7 #define as politicas de acesso firewall
8 iptables -P INPUT DROP
9 iptables -P OUTPUT DROP
10 iptables -P FORWARD DROP
11 #
12 #libera acesso ao loopback
13 iptables -A INPUT -i lo -j ACCEPT
14 iptables -A OUTPUT -o lo -j ACCEPT
15 #
16 #libera trafego icmp
17 iptables -A INPUT -i eth0 -s 10.0.2.0/24 -p icmp --icmp-type \
18     echo-request -j ACCEPT
19 iptables -A OUTPUT -o eth0 -d 10.0.2.0/24 -p icmp --icmp-type \
20     echo-reply -j ACCEPT
```

Figura 18 – Aprimoramento das regras
Fonte: Elaborado pelo autor (2018)

Por meio da linha 17 da figura acima, pode-se observar a especificação da interface (-i eth0) cujo tráfego de entrada no firewall deverá ser monitorado, da rede que poderá originar pacotes ICMP para o servidor (-s 10.0.2.0/24) e, finalmente, o tipo de ICMP a ser aceito (--icmp-type echo-request). Analogamente, a linha 18 descreve as condições para que os pacotes ICMP aceitos pela regra de entrada possam ser respondidos. Estritamente em relação ao IPTables, tem-se:

-i: *interface* cujo tráfego entrante deverá ser monitorado. Trabalha conjuntamente com a chain INPUT;

-o: *interface* cujo tráfego “saindo” deverá ser monitorado. Trabalha conjuntamente com a chain OUTPUT;

-s: rede de origem (source) do tráfego monitorado;

-d: rede de destino (destination) do tráfego monitorado;

-p: protocolo (não confundir com -P, de policy).

Por fim, cabe ressaltar ser a barra invertida (\) utilizada no script apenas para permitir a quebra de linhas, assim, facilitando a leitura.

4.5 Configurando regras específicas: serviço HTTP

A liberação do serviço HTTP pode ser feita de maneira semelhante ao feito para o tráfego ICMP devendo-se desta vez, entretanto, especificar não apenas o protocolo a ser utilizado na camada de transporte, mas também, a porta de destino da conexão.

Na linha 23 da figura “Liberação das requisições HTTP”, a opção `-p tcp` especifica o protocolo TCP para transporte do tráfego tendo como destino a porta 80 (`--dport 80`), caracterizando assim, o uso do protocolo HTTP (TCP/80). Entretanto, o uso do TCP remete também ao estabelecimento de conexão. A porta de destino da conexão foi especificada como 80, porém, a porta de origem da conexão poderá ser qualquer uma livre entre 1024 e 65535 dificultando, assim, a configuração do retorno da requisição.

Uma solução adotada até pouco tempo atrás, consistia na configuração da política de OUTPUT para ACCEPT, o que permitiria que qualquer pacote saísse pelo firewall. Todavia, conforme já discutido, isso poderia permitir também que códigos maliciosos tirassem proveito dessa política para abrirem backdoors ou mesmo promover movimentação lateral na rede.

```
1 #!/bin/bash
2 clear
3 #descarrega regras pre existentes
4 iptables -F
5 iptables -X
6 #
7 #define as politicas de acesso firewall
8 iptables -P INPUT DROP
9 iptables -P OUTPUT DROP
10 iptables -P FORWARD DROP
11 #
12 #libera acesso ao loopback
13 iptables -A INPUT -i lo -j ACCEPT
14 iptables -A OUTPUT -o lo -j ACCEPT
15 #
16 #libera trafego icmp
17 iptables -A INPUT -i eth0 -s 10.0.2.0/24 -p icmp --icmp-type \
18     echo-request -j ACCEPT
19 iptables -A OUTPUT -o eth0 -d 10.0.2.0/24 -p icmp --icmp-type \
20     echo-reply -j ACCEPT
21 #
22 #libera servico HTTP
23 iptables -A INPUT -i eth0 -s 10.0.2.0/24 -p tcp --dport 80 -j ACCEPT
```

Figura 19 – Liberação das requisições HTTP

Fonte: Elaborado pelo autor (2018)

A melhor opção, portanto, recai sobre o uso de firewalls stateful, ou seja, firewalls que mantêm registros acerca das conexões permitindo, desta forma, que pacotes que tentem deixar o firewall por meio de uma conexão previamente estabelecida, sejam reconhecidos como resposta à requisição que originou a conexão e, portanto, considerados seguros e liberados para sair.

```
3 #descarrega regras pre existentes
4 iptables -F
5 iptables -X
6 #
7 #define as politicas de acesso firewall
8 iptables -P INPUT DROP
9 iptables -P OUTPUT DROP
10 iptables -P FORWARD DROP
11 #
12 #libera acesso ao loopback
13 iptables -A INPUT -i lo -j ACCEPT
14 iptables -A OUTPUT -o lo -j ACCEPT
15 #
16 #habilita analise stateful
17 iptables -A OUTPUT -o eth0 -d 10.0.2.0/24 -m conntrack \
18     --ctstate ESTABLISHED -j ACCEPT
19 #
20 #libera trafego icmp
21 iptables -A INPUT -i eth0 -s 10.0.2.0/24 -p icmp --icmp-type \
22     echo-request -j ACCEPT
23 #
24 #libera servico HTTP
25 iptables -A INPUT -i eth0 -s 10.0.2.0/24 -p tcp --dport 80 -j ACCEPT
```

Figura 20 – Ativação da análise *stateful*

Fonte: Elaborado pelo autor (2018)

A ativação da análise de pacotes *stateful* é possibilitada por meio de um módulo do *kernel* denominado *conntrack*, abreviação de *connection tracking*, o qual constrói a *connection tracking table* já referenciada. A Figura “Ativação da análise *stateful*” ilustra a ativação da análise *stateful*. Na linha 17, a opção *-m* (*match*) especifica que pacotes que tenham registros na tabela de conexões (*conntrack*) tenham sua saída liberada quando o fizerem por meio de uma conexão previamente estabelecida (*--ctstate ESTABLISHED*).

No caso do serviço HTTP, isso significa que a mesma conexão utilizada para solicitação da página, será usada também para sua entrega, sem a necessidade de configurar uma regra para isso. Embora o protocolo ICMP não estabeleça conexões, o módulo *conntrack* é capaz de analisar seu tráfego, razão pela qual a linha que liberava sua saída de pacotes ICMP (linha 19, Figura “Liberação das requisições HTTP”) também foi descartada.

4.6 Configurando regras específicas: serviço SSH

Analogamente ao serviço HTTP, a liberação do serviço SSH também se dará com base no protocolo da camada de transporte e porta de destino no servidor: TCP/22. Entretanto, dessa vez, apenas o *host Debian1* poderá originar tal acesso ficando, portanto, esta regra:

```
iptables -A INPUT -i eth0 -s 10.0.2.22 -p tcp -dport 22 -j ACCEPT
```

Comando de prompt 2 – Liberação da porta 22
Fonte: Elaborado pelo autor (2018)

Ao ser recarregado, o *script* permitirá, com base nessa nova linha, que acessos via SSH originados pelo *host* do administrador (*root*) possam acessar remotamente o servidor para fins administrativos.

4.7 Configurando regras específicas: logs de acessos

A configuração do firewall não estará completa se trilhas de auditoria consistentes (*logs*) não forem geradas. Os acessos (e **tentativas**) deverão ser logados antes mesmo de serem liberados, sendo armazenados no arquivo */var/log/messages*.

No *IPTables*, os *logs* são ativados por meio da *target* LOG, recomendando-se que: (a) essas sejam complementadas por identificadores que facilitem sua localização dentro do *messages*; e ainda que, (b) seja adequadamente especificado o nível de *log* a utilizar. O quadro abaixo traz a íntegra do *script* do firewall, incluindo a geração de *logs*.


```
#!/bin/bash
clear
#descarrega regras preexistentes
iptables -F
iptables -X
#
#define as politicas de acesso firewall
iptables -P INPUT DROP
iptables -P OUTPUT DROP
iptables -P FORWARD DROP
#
#libera acesso ao loopback
iptables -A INPUT -i lo -j ACCEPT
iptables -A OUTPUT -o lo -j ACCEPT
#
#habilita analise stateful
iptables -A OUTPUT -o eth0 -d 10.0.2.0/24 -m conntrack \
--ctstate ESTABLISHED -j ACCEPT
#
#libera trafego icmp
iptables -A INPUT -i eth0 -s 10.0.2.0/24 -p icmp --icmp-type \
echo-request -j LOG --log-prefix "ICMP: "
--log-level info
iptables -A INPUT -i eth0 -s 10.0.2.0/24 -p icmp --icmp-type \
echo-request -j ACCEPT
#
#libera servico HTTP
iptables -A INPUT -i eth0 -s 10.0.2.0/24 -p tcp --dport 80 -j
ACCEPT
#
#libera servico SSH para o host Debian1
iptables -A INPUT -i eth0 -s 10.0.2.22 -p tcp --dport 22 -j
LOG \
--log-prefix "SSH: " --
log-level info
iptables -A INPUT -i eth0 -s 10.0.2.22 -p tcp --dport 22 -j
ACCEPT
```

Código-fonte 1 – Íntegra do script do firewall
Fonte: Elaborado pelo autor (2019)

5 LOGS, TABELAS DE CONEXÕES E OUTROS

5.1 Elementos relevantes

Outros elementos relevantes e relacionados aos firewalls, aos quais deve-se dispensar a devida atenção, são descritos nesta seção.

5.1.1 Tabela de conexões

O quadro abaixo traz a tabela de conexões do firewall (*connection tracking table*) criado, a qual reside em `/proc/net/nf_conntrack`. Vale ressaltar que o acesso a esta tabela requer privilégios administrativos (root).

```

ipv4 2 udp 17 169 src=127.0.0.1 dst=127.0.0.1 sport=42011 dport=42011 packets=1 bytes=48 src=127.0.0.1 dst=127.0.0.1
sport=42011 dport=42011 packets=503 bytes=252468 [ASSURED] mark=0 secmark=0 use=1

ipv4 2 tcp 6 53 TIME_WAIT src=10.0.2.22 dst=10.0.2.21 sport=34910 dport=22 packets=24 bytes=3848 src=10.0.2.21
dst=10.0.2.22 sport=22 dport=34910 packets=24 bytes=5902 [ASSURED] mark=0 secmark=0 use=1

ipv4 2 tcp 6 74 TIME_WAIT src=10.0.2.22 dst=10.0.2.21 sport=34912 dport=22 packets=35 bytes=4356 src=10.0.2.21
dst=10.0.2.22 sport=22 dport=34912 packets=43 bytes=77482 [ASSURED] mark=0 secmark=0 use=1

```

Quadro 2 – Tabela de conexões (*connection tracking table*)
Fonte: Elaborado pelo autor (2018)

Tomando-se como referência a linha em destaque no quadro acima, tem-se:

Nome do protocolo	ipv4 2	
Número do protocolo	tcp 6 (6 = TCP ; 17 = UDP)	
Tempo até a entrada expirar (seg.)	74	
Estado da conexão (somente TCP)	TIME_WAIT	
Sentido	Lado que originou a conexão	Lado que recebeu a conexão
Endereço de origem da conexão	10.0.2.22	10.0.2.21
Endereço de destino da conexão	10.0.2.21	10.0.2.22
Porta de origem da conexão	34912	22
Porta de destino da conexão	22	34912
Pacotes enviados	35	43
Bytes enviados	4356	77482
[ASSURED]	se esta conexão já recebeu tráfego em ambas as direções (UDP) ou ACK em uma conexão ESTABLISHED (TCP). Caso contrário, não está presente.	

Quadro 3 – Principais campos da Tabela de conexões do firewall
Fonte: Elaborado pelo autor (2018)

5.2 Listagem das regras (Tabela FILTER)

O quadro “Principais campos da Tabela de conexões do *firewall*” ilustra a saída do comando ***iptables -L***, o qual lista as regras residentes na memória do *firewall* criado.

Chain INPUT (policy DROP)			
target	prot opt source	destination	
ACCEPT	all -- anywhere	anywhere	
LOG	icmp -- 10.0.2.0/24	anywhere	icmp echo-request LOG level info prefix 'ICMP: '
ACCEPT	icmp -- 10.0.2.0/24	anywhere	icmp echo-request
ACCEPT	tcp -- 10.0.2.0/24	anywhere	tcp dpt:www
ACCEPT	tcp -- 10.0.2.0/24	anywhere	tcp dpt:www
LOG	tcp -- 10.0.2.22	anywhere	tcp dpt:ssh LOG level info prefix 'SSH: '
Chain FORWARD (policy DROP)			
target	prot opt source	destination	
Chain OUTPUT (policy DROP)			
target	prot opt source	destination	
ACCEPT	all -- anywhere	anywhere	
ACCEPT	all -- anywhere	10.0.2.0/24	ctstate ESTABLISHED

Quadro 4 – Listagem das regras residentes em memória
Fonte: Elaborado pelo autor (2018)

A coluna **target** lista a ação a ser executada por cada regra, em cada tipo de fluxo de dados (*chain*) – *INPUT*, *FORWARD* e *OUTPUT*, lembrando que eles têm como referência a interface especificada (*eth0*). As demais colunas são autoexplicativas.

5.3 Logs de acesso SSH

O quadro abaixo ilustra parcialmente os *logs* dos tráfegos ICMP e SSH criados pelo firewall, armazenados no arquivo */var/log/messages*.

```
May 13 20:08:27 metasploitable kernel: [13174.319421] SSH: IN=eth0 OUT=  
MAC=08:00:27:a5:22:dc:08:00:27:98:ee:12:08:00 SRC=10.0.2.22 DST=10.0.2.21 LEN=60 TOS=0x00 PREC=0x00  
TTL=64 ID=6248 DF PROTO=TCP SPT=34906 DPT=22 WINDOW=29200 RES=0x00 SYN URGP=0
```

```
May 13 20:08:27 metasploitable kernel: [13174.321065] SSH: IN=eth0 OUT=  
MAC=08:00:27:a5:22:dc:08:00:27:98:ee:12:08:00 SRC=10.0.2.22 DST=10.0.2.21 LEN=52 TOS=0x00 PREC=0x00  
TTL=64 ID=6249 DF PROTO=TCP SPT=34906 DPT=22 WINDOW=229 RES=0x00 ACK URGP=0
```

```
May 13 20:08:50 metasploitable kernel: [13197.571260] ICMP: IN=eth0 OUT=  
MAC=08:00:27:a5:22:dc:08:00:27:98:ee:12:08:00 SRC=10.0.2.22 DST=10.0.2.21 LEN=84 TOS=0x00 PREC=0x00  
TTL=64 ID=5002 DF PROTO=ICMP TYPE=8 CODE=0 ID=2011 SEQ=1
```

```
May 13 20:08:51 metasploitable kernel: [13198.578388] ICMP: IN=eth0 OUT=  
MAC=08:00:27:a5:22:dc:08:00:27:98:ee:12:08:00 SRC=10.0.2.22 DST=10.0.2.21 LEN=84 TOS=0x00 PREC=0x00  
TTL=64 ID=5081 DF PROTO=ICMP TYPE=8 CODE=0 ID=2011 SEQ=2
```

Quadro 5 – Logs parciais SSH e ICMP
Fonte: Elaborado pelo autor (2018)

No destaque, observa-se que às 20:08:27 horas do dia 13 de maio do ano corrente, o *host Metasploitable* (DST=10.0.2.21) recebeu uma solicitação de conexão (SYN) SSH (PROTO=TCP ; DPT=22) do *host* 10.0.2.22, originada por este na porta 34906 (SPT=34906). No registro seguinte, a flag ACK indica que a conexão foi executada com sucesso.

Apesar do *IPTables* ser uma ferramenta bastante interessante, tem-se aqui como foco, os **conceitos abordados e não a ferramenta** propriamente dita, pois os princípios da filtragem de pacotes podem ser aplicados a qualquer ferramenta ou *appliance*. O conhecimento adequado da pilha TCP/IP é **fundamental** para entendimento dos conceitos envolvidos.

Uma ferramenta interessante para gerenciamento de firewalls por meio de interfaces gráficas (GUI) *drag-and-drop* é o *FirewallBuilder*. Ele consiste em uma aplicação licenciada sob o modelo GPL, capaz de configurar o *IPTables*, Cisco ASA/PIX e Cisco ACLs, dentre outros, conforme apresentado abaixo:

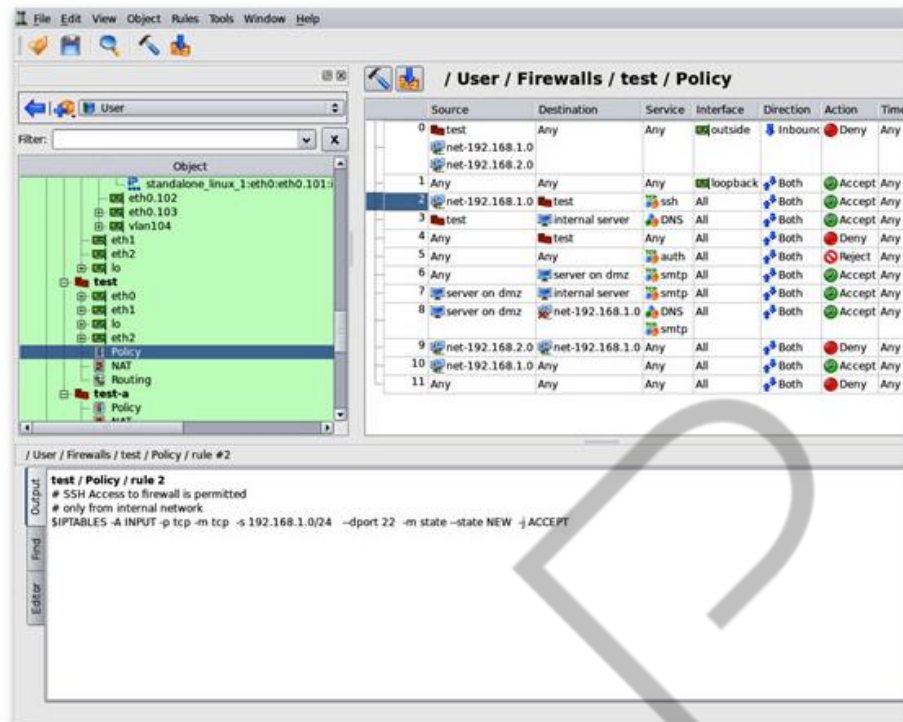


Figura 21 – Exemplo de regra no IPTables para liberação do SSH
 Fonte: <http://fwbuilder.sourceforge.net/images/screenshot1.png> (2018)

6 ENCAMINHAMENTO DE PACOTES E NAT

Na prática, observa-se que a maior parte das empresas recebe de seus ISP's (*Internet Service Providers* – Provedores de Acesso à *Internet*) uma quantidade limitada de IPs publicamente roteáveis. Em função disso, surge a necessidade de compartilhamento do acesso aos serviços *Internet* sem, entretanto, que venha a ser atribuído um endereço público a cada *host* da rede local os quais, mais frequentemente, se utilizam de endereços IP privativos para acesso a serviços internos (disponibilizados na rede local) e externos (disponibilizados na *Internet*). Dentre outras funcionalidades, os *firewalls* de borda podem rotear o tráfego originado na *Internet* para o *host* de destino na rede local e vice-versa, de forma mais segura; submetendo este tráfego às políticas de acesso determinadas pela organização. O *IPTables* permite a implementação de tais políticas por intermédio da *chain FORWARD*, a qual permite ao administrador do firewall disciplinar o tráfego trocado entre a rede local (confiável) e a rede externa (*Internet*, não confiável). Tome-se como referência a topologia representada pela Figura “Topologia de referência 2 – Acesso à *Internet*”.

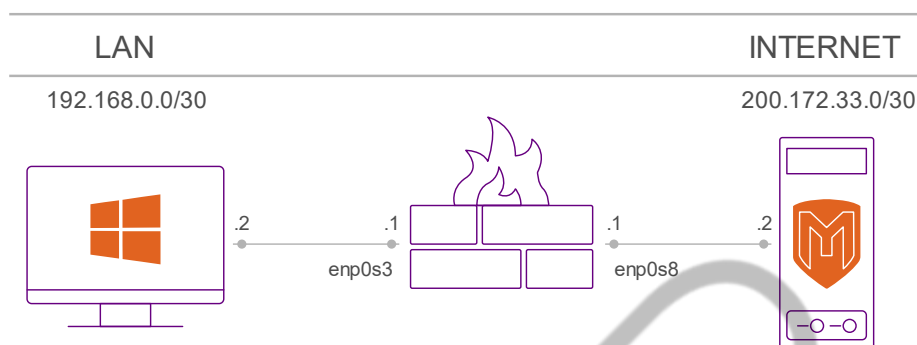


Figura 22 – Topologia de referência 2 – Acesso à *Internet*
Fonte: Elaborado pelo autor (2020)

Na Figura “Topologia de referência 2 – Acesso à *Internet*” há um *firewall* de borda intermediando o tráfego trocado entre os *hosts* da rede local (LAN) e a *Internet*. Consiste o referido ativo de um *host Linux* no qual a implementação do *IPTables* foi feita de maneira que uma *interface* esteja conectada à LAN – identificada na referida figura como enp0s3, e outra *interface* conectada à *Internet* – identificada como enp0s8. Vale destacar que tais denominações são orientativas, podendo sofrer variações em função da implementação. Alguns pontos básicos, porém relevantes, devem ser observados em relação à implementação ilustrada pela Figura “Topologia de referência 2 – Acesso à *Internet*”:

1. O endereço IP da *interface* do firewall conectada à rede local (LAN) deve ser fixo;
2. O endereço IP da *interface* do firewall conectada à rede externa (*Internet*) pode ser fixo ou dinâmico;
3. Os endereços atribuídos aos *hosts* da rede local deverão ser privativos, conforme definido pela RFC1918.

O encaminhamento de pacotes entre *interfaces* é feito pelo *IPTables* por intermédio da *chain FORWARD*. Admitindo-se que o *host Windows 7* residente na LAN da topologia de referência (Figura “Topologia de referência 2 – Acesso à Internet”) desejasse acessar o serviço HTTP do servidor alocado na *Internet* – na referida figura representado pelo *host Metasploitable2*, o encaminhamento do tráfego da *interface enp0s3* para a *interface enp0s8* poderia ser feito, essencialmente, com a implementação das instruções descritas no Quadro “*Chain FORWARD*”.

```
iptables -A FORWARD -i enp0s3 -j ACCEPT
iptables -A FORWARD -o enp0s8 -j ACCEPT
```

Comando de prompt 3 – Chain FORWARD
Fonte: Elaborado pelo autor (2020)

Por padrão, entretanto, o *kernel Linux* mantém desabilitada a função de encaminhamento de pacotes podendo ser habilitada mediante ajuste do valor do parâmetro *ip_forward* do *kernel*, a exemplo do descrito no Quadro “Habilitação do encaminhamento de pacotes no *kernel*”.

```
sysctl -w net.ipv4.ip_forward=1
cat /proc/sys/net/ipv4/ip_forward
```

Comando de prompt 4 – Habilitação do encaminhamento de pacotes no kernel
Fonte: Elaborado pelo autor (2020)

A primeira instrução no Quadro “Habilitação do encaminhamento de pacotes no *kernel*” utiliza a ferramenta *sysctl* para alterar o valor armazenado no parâmetro *ip_forward* para 1, onde 0 significa que o encaminhamento de pacotes está desabilitado e 1 que está habilitado. A segunda instrução indicada no quadro verifica o estado atual do encaminhamento de pacotes.

6.1 A tabela NAT (*Network Address Translation*)

A tabela NAT controla a tradução dos endereços IP do tráfego que atravessa o *host Linux* utilizado como dispositivo de borda, tráfego este originado ou direcionado às diferentes redes conectadas ao referido *host*. A tabela NAT possui 3 *chains*:

- **PREROUTING:** utilizada quando os pacotes precisam ser modificados logo que chegam à *interface*. Ideal para realização de DNAT (*destination NAT*) e redirecionamento de portas.
- **OUTPUT:** utilizada quando os pacotes gerados localmente precisam ser modificados antes de serem roteados. Esta *chain* é consultada apenas para conexões originadas pelo endereços IP das *interfaces* locais.
- **POSTROUTING:** utilizada quando os pacotes precisam ser modificados após o tratamento de roteamento. Ideal para realização de SNAT (*source NAT*) e IP *Masquerading*.

Vale citar ainda a existência da tabela *Mangle* a qual, simplificada, é utilizada para alterações especiais nos pacotes, por exemplo, para modificação do tipo de serviço (TOS). Entretanto, esta tabela extrapola o escopo desta documentação. O *Masquerading* é utilizado quando *hosts* de uma rede interna precisam compartilhar o acesso à *Internet* por intermédio de um *host Linux* executando o *IPTables*. Neste contexto, tem-se:

- Quando o interessado utiliza um tipo de conexão que disponibiliza endereço IP público dinâmico, então, o IP *masquerading* deve ser empregado. O *masquerading* (mascaramento) é um exemplo de SNAT.
- Quando o interessado utiliza um tipo de conexão que disponibiliza endereço público fixo, então, o SNAT (*source nat*) deve ser empregado. O SNAT consiste em modificar o endereço IP de origem dos *hosts* clientes antes que os pacotes venham a ser enviados. A Figura “Operação SNAT” representa simplificada como o SNAT opera: encapsulando os endereços IP dos *hosts* da rede local no IP público atribuído à *interface* do *firewall* conectada à rede externa, permitindo, desta forma, que os referidos *hosts* tenham acesso à esta última – geralmente, a Internet.

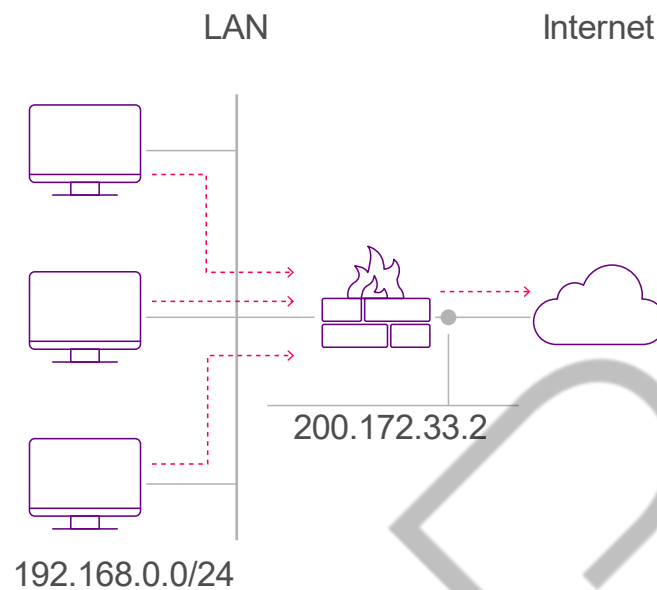


Figura 23 - Operação SNAT
Fonte: Elaborado pelo autor (2020)

Com base na topologia ilustrada pela Figura “Operação SNAT”, o compartilhamento da conexão com a Internet entre os hosts da rede local poderia ser feito conforme descrito no Quadro “Configuração do SNAT”.

```
iptables -t nat -A POSTROUTING -s 192.168.0.0/24 -o enp0s8 -j  
SNAT --to 200.172.33.2
```

Comando de prompt 5 – Configuração do SNAT
Fonte: Elaborado pelo autor (2020)

- Por sua vez, o DNAT (*destination nat*) consiste em modificar o endereço de destino dos *hosts* clientes. O DNAT é amplamente utilizado para redirecionamento de pacotes, *proxies* transparentes e balanceamento de carga.

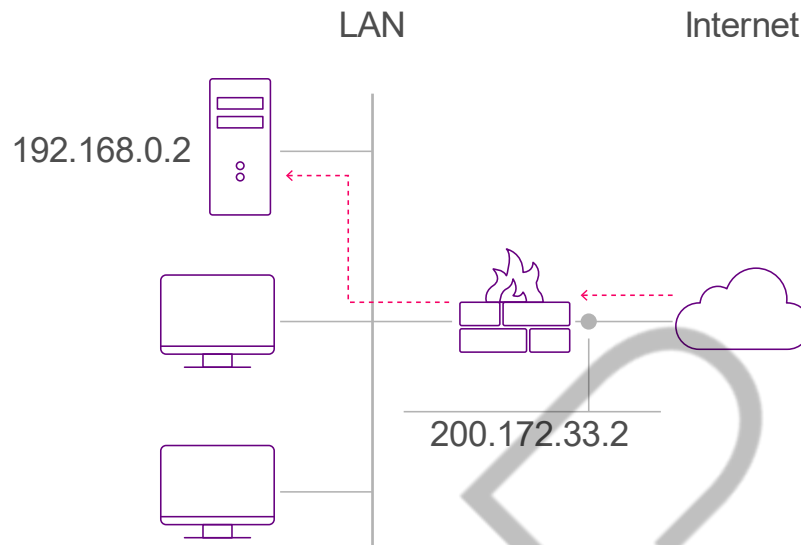


Figura 24 - Exemplo de uso do DNAT
Fonte: Elaborado pelo autor (2020)

Com base na topologia ilustrada pela Figura “Operação DNAT”, a publicação do servidor 192.168.0.2 poderia ser feita conforme descrito no Quadro “Configuração do DNAT”.

```
iptables -t nat -A PREROUTING -s 200.172.33.2 -i enp0s8 -j  
DNAT --to 192.168.0.2
```

Comando de prompt 6 – Configuração do DNAT
Fonte: Elaborado pelo autor (2020)

A Figura “Esquema da tabela NAT” ilustra sucintamente o funcionamento da tabela NAT.

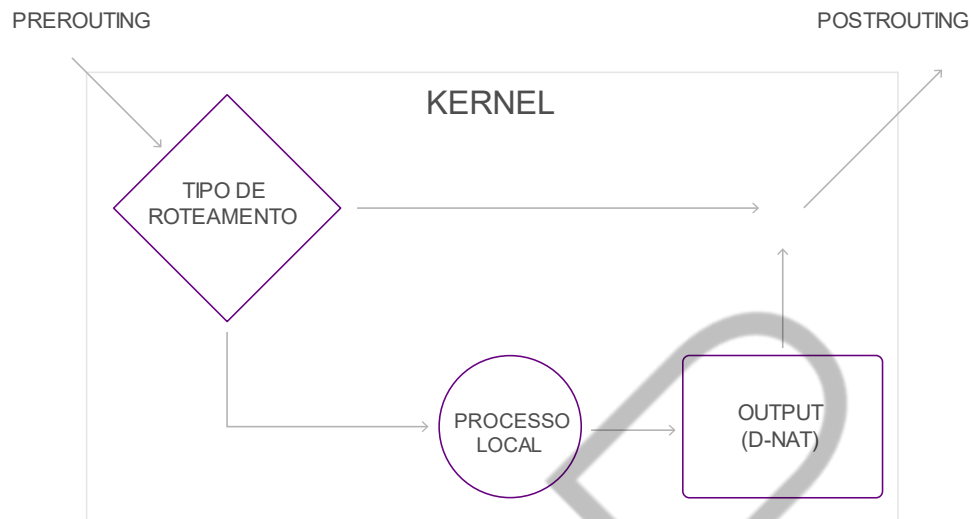


Figura 25 - Esquema da tabela NAT
 Fonte: <http://eriberto.pro.br/iptables/3.html> (2020)

7 HANDS ON 2 – COMPARTILHAMENTO DE CONEXÃO

Neste novo *hands on*, toma-se como referência a topologia ilustrada pela Figura “Topologia de referência 2– Acesso à Internet” a fim de demonstrar o uso da tabela NAT para compartilhamento da conexão com a Internet. A Tabela “Configurações das VMs” detalha as configurações de cada das máquinas virtuais a serem empregadas para a tarefa.

	Host	Firewall	Server
Sistema operacional	Windows7	Debian 10	Metasploitable2
Interface de rede 1	Rede interna(Nome: LAN)	Rede interna(Nome: LAN)	Rede interna(Nome: WAN)
Interface de rede 2	---	Rede interna(Nome:WAN)	---
Memória RAM	1GB	1GB	1GB

Tabela 2 – Configurações das VMs
 Fonte: Elaborado pelo autor (2020)

Vale reforçar que a VM a ser utilizada pelo *firewall* deverá ser provida de duas *interfaces*, uma a ser conectada ao *host* de testes residente na rede local do cenário (*interface* LAN), e a outra a ser conectada ao servidor que simula a *Internet* (*Metasploitabe* 2). A Figura “Configuração da LAN – Firewall” ilustra a configuração da *interface* LAN do *firewall*.

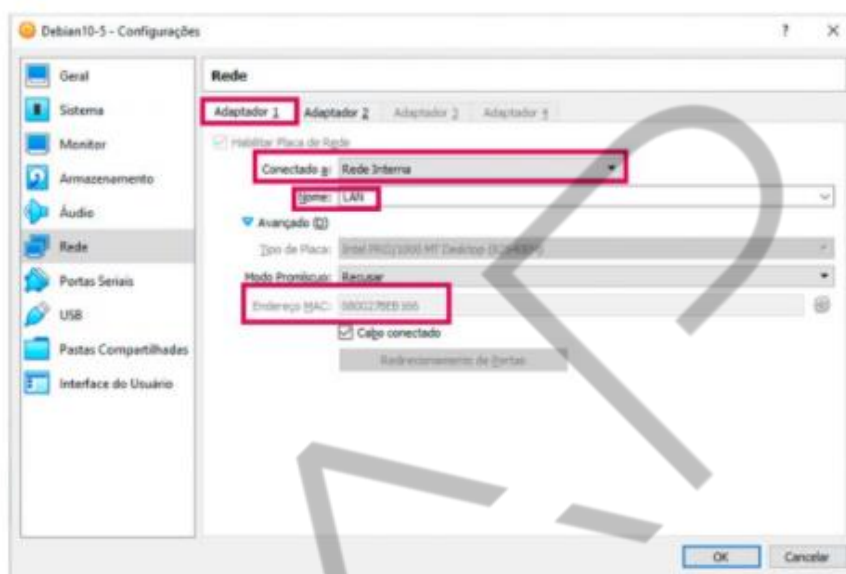


Figura 26 – Configuração da LAN – Firewall
Fonte: Elaborado pelo autor (2020)

Na Figura “Configuração da LAN – *Firewall*” podem ser observadas as configurações da respectiva *interface*, conforme apontado na Tabela “Configurações das VMs”.

A Figura “Configuração da WAN – *Firewall*” ilustra a configuração da interface WAN do *firewall*.

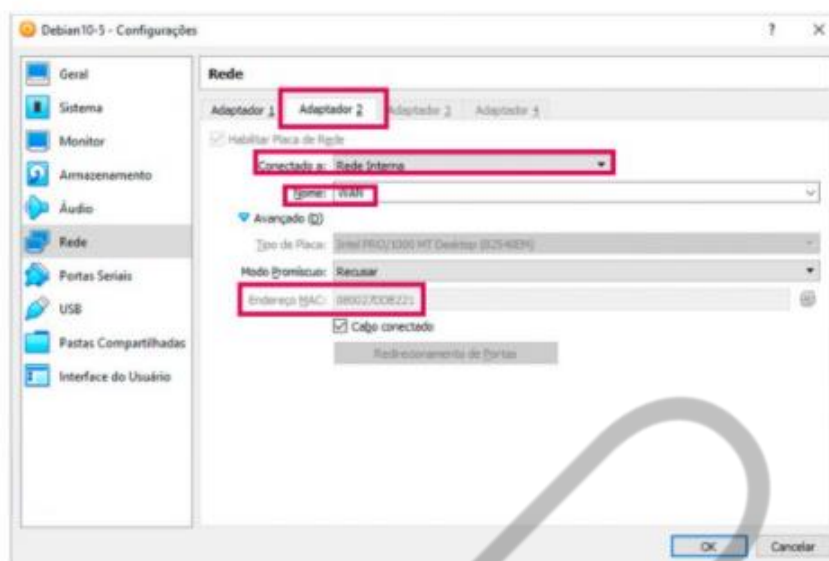


Figura 27 – Configuração da WAN – Firewall
Fonte: Elaborado pelo autor (2020)

O acesso a tais caixas de diálogo é feito destacando-se a VM desejada no painel esquerdo do *VirtualBox*, na sequência clicando em Configurações -> Rede. O nome das redes (LAN e WAN) deverá ser digitado na caixa de texto Nome (Figura Configuração da WAN – Firewall).

7.1 Considerações sobre a configuração de cada VM

- **VM Server:** esta VM representa o servidor na *Internet* a ser acessado pelo *host* de testes. Assim sendo, a esta foi manualmente atribuído o endereço IP 200.172.33.2 (ver Quadro “Configuração do endereço IP – VM Server”), diretamente a partir do console. Vale ressaltar que desta forma tal configuração é volátil, e será perdida quando o *host* for reinicializado.

```
sudo ifconfig eth0 200.172.33.2 netmask 255.255.255.252
```

Comando de prompt 7 – Configuração do endereço IP – VM server
Fonte: Elaborado pelo autor (2020)

- **VM Firewall:** esta VM representa o firewall que proverá aos hosts da LAN do cenário, acesso à *Internet*. Assim sendo, endereços IP fixos foram atribuídos tanto à respectiva *interface* LAN, quanto à respectiva *interface* WAN. Desta vez, entretanto, tais endereços foram atribuídos de forma persistente, por meio da configuração do arquivo */etc/network/interfaces* conforme escrito no Quadro.

```
# This file describes the network interfaces available on your
system
# and how to activate them. For more information, see inter-
faces(5) .

source /etc/network/interfaces.d/*

# The loopback network interface
auto lo
iface lo inet loopback

# The primary network interface
allow-hotplug enp0s3
iface enp0s3 inet static
address 192.168.0.1/30
#gateway 192.168.0.1

# The secondary network interface
allow-hotplug enp0s8
iface enp0s8 inet static
address 200.172.33.1/30
#gateway 200.172.33.1
```

Código-fonte 2 – Configuração dos endereços IP – VM firewall

Fonte: Elaborado pelo autor (2019)

- **VM Cliente:** esta VM representa o *host* de teste residente na LAN do cenário, sendo esta também configurada com IP fixo, por intermédio das caixas de diálogo “Propriedades de Protocolo TCP/IP versão 4” do Windows (Figura “Configuração dos endereços IP – VM *host*”).

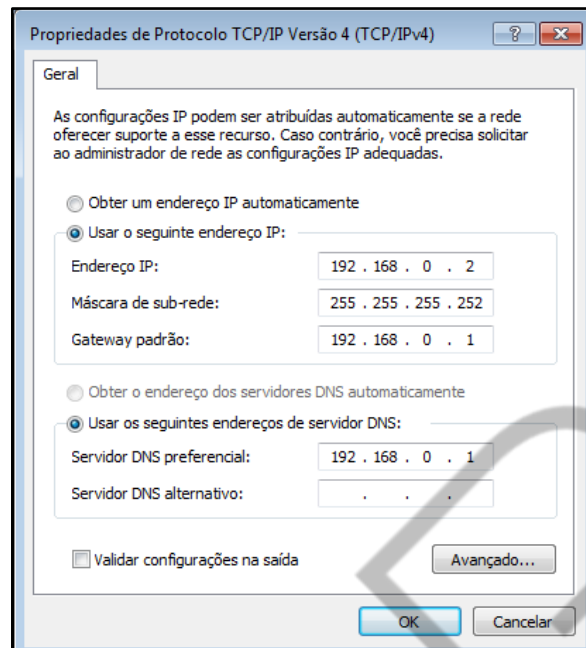


Figura 28 – Configuração dos endereços IP – VM host
Fonte: Elaborado pelo autor (2020)

Com o ambiente já devidamente operacional, é possível iniciar a construção do firewall *IPTables* com base no *script* do Quadro “*Script fw_nat*”.

```
#!/bin/bash
#
fwd_reset(){
# procedure para restaurar o estado original do host
sysctl -w net.ipv4.ip_forward=0
iptables -F
iptables -t nat -F
iptables -P INPUT ACCEPT
iptables -P OUTPUT ACCEPT
iptables -P FORWARD ACCEPT
}
#
fwd_load(){
# procedure para carga do firewall
sysctl -w net.ipv4.ip_forward=1
# descarrega regras preexistentes
iptables -F
iptables -t nat -F
#
# define politicas de acesso
iptables -P INPUT DROP
iptables -P OUTPUT DROP
iptables -P FORWARD DROP
#
# libera acesso ao loopback
```

```
iptables -A INPUT -i lo -j ACCEPT
iptables -A OUTPUT -o lo -j ACCEPT
#
# habilita SNAT sobre a interface publica
iptables -t nat -A POSTROUTING -s $lan -j SNAT --to $iWan
#
# habilita analise stateful
iptables -A FORWARD -m conntrack --ctstate ESTABLISHED -j
ACCEPT
#
# regras de acesso
iptables -A FORWARD -i enp0s3 -p icmp --icmp-type echo-
request -j ACCEPT
iptables -A FORWARD -i enp0s3 -p tcp --dport 22 -j LOG --
log-prefix SSH: --log-level warning
iptables -A FORWARD -i enp0s3 -p tcp -m multiport --dports
22,80 -j ACCEPT
}
#
main(){
# procedure principal
#
# definicoes gerais
lan='192.168.0.0/30'
wan='200.172.33.0/30'
iLan=$(hostname -I | cut -d " " -f 1)
iWan=$(hostname -I | cut -d " " -f 2)
#
clear
echo -e "FIREWALL IPTABLES\n"
echo "STATUS:"
echo "Interface LAN: $iLan"
echo "Interface WAN: $iWan"
#
sysctl net.ipv4.ip_forward
echo -e "\nOpcoes"
echo "1. Carregar firewall"
echo "2. Descarregar firewall"
echo "3. Listar regras [FILTER]"
echo "4. Listar regras [NAT]"
echo "5. Exibir logs [SSH]"
echo "6. Exibir tabela de conexoes"
echo "*. Sair (teclar qqer outro valor)"
read opt
#
case $opt in
    1) fwd_load ; main ;;

    2) fwd_reset ; main ;;
```



```

3) clear ; echo -e "\n\033[0;46m >>Tabela FILTER
\033[0m"
    /usr/sbin/iptables -L -v
    echo -e "\n\033[0;36m>>Tecle algo para retor-
nar\033[0m"
    read ; main ;;

4) clear ; echo -e "\n\033[0;46m >>Tabela NAT \033[0m"
    /usr/sbin/iptables -t nat -L -v
    echo -e "\n\033[0;36m>>Tecle algo para retor-
nar\033[0m"
    read ; main ;;

5) clear ; echo -e "\n\033[0;46m >>Logs SSH \033[0m"
    grep SSH /var/log/syslog
    echo -e "\n\033[0;36m>>Tecle algo para retor-
nar\033[0m"
    read ; main ;;

6) clear ; echo -e "\n\033[0;46m >>Conntrack Table
\033[0m"
    cat /proc/net/nf_conntrack 2>/dev/null
    echo -e "\n\033[0;36m>>Tecle algo para retor-
nar\033[0m"
    read ; main ;;

*) clear ;
    echo -e "\n\033[1;46m_____ATENCAO_____ \033[0m"
    echo -e "\033[0;36m Script encerrado, status do fire-
wall inalterado \033[0m\n";;
esac
}
#
if [ $(id -u) -ne 0 ]; then
    clear
    echo -e "Voce nao possui privilegios suficientes para exe-
cutar este script\n" ; exit
else
    main
fi

```

Código-fonte 3 – Script fw_nat
Fonte: Elaborado pelo autor (2020)

A execução do *script* exige que o usuário tenha privilégios de *root*, assim sendo, estes são verificados antes que o menu principal seja carregado. Caso o usuário não possua tais privilégios, a execução do *script* é encerrada (Figura “Mensagem de finalização do *script*”).

```
Voce nao possui privilegios suficientes para executar este script
user1@kraken:~/firewall$
```

Figura 29 – Mensagem de finalização do *script*
Fonte: Elaborado pelo autor (2020)

Ao ser devidamente iniciado, o *script* apresentará o menu ilustrado pela Figura “Menu principal do firewall”.

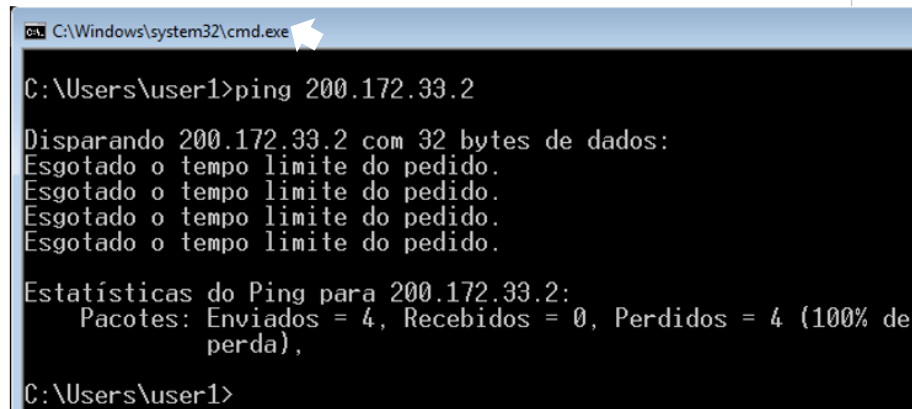
```
FIREWALL IPTABLES

STATUS:
Interface LAN: 192.168.0.1
Interface WAN: 200.172.33.1
net.ipv4.ip forward = 0

Opcoes
1. Carregar firewall
2. Descarregar firewall
3. Listar regras [FILTER]
4. Listar regras [NAT]
5. Exibir logs [SSH]
6. Exibir tabela de conexoes
*. Sair (teclar qqr outro valor)
```

Figura 30 – Menu principal do firewall
Fonte: Elaborado pelo autor (2020)

As informações a respeito dos endereços IP atribuídos às interfaces de rede são verificadas automaticamente pelo script, assim como o status do encaminhamento de pacotes. O destaque na referida figura indica o parâmetro `ip_forward = 0` (padrão do kernel) indicando, portanto, estar o encaminhamento de pacotes desabilitado no kernel. Assim sendo, o host de testes (VM Windows 7) é incapaz acessar qualquer serviço disponibilizado pelo servidor (VM Metasploitable 2), e mesmo, de executar testes de conectividade com este (Figura “Teste de conectividade com o servidor”).



```
C:\Windows\system32\cmd.exe
C:\Users\user1>ping 200.172.33.2

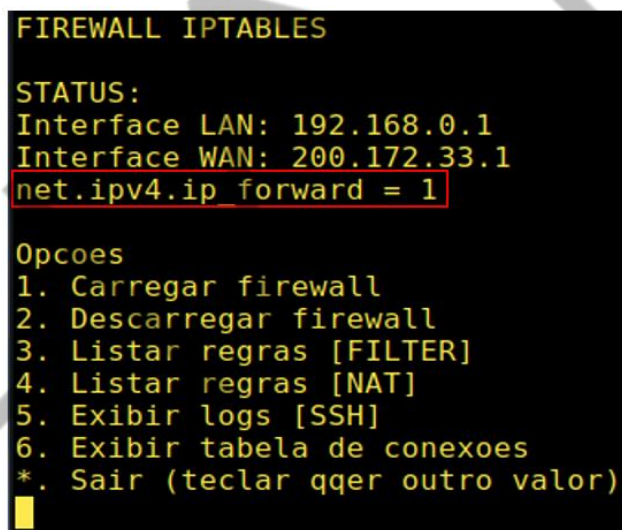
Disparando 200.172.33.2 com 32 bytes de dados:
Esgotado o tempo limite do pedido.
Esgotado o tempo limite do pedido.
Esgotado o tempo limite do pedido.
Esgotado o tempo limite do pedido.

Estatísticas do Ping para 200.172.33.2:
    Pacotes: Enviados = 4, Recebidos = 0, Perdidos = 4 (100% de perda),

C:\Users\user1>
```

Figura 31 – Teste de conectividade com o servidor
Fonte: Elaborado pelo autor (2020)

Por meio agora da opção 1 do menu principal do *firewall*, o encaminhamento de pacotes é habilitado ao carregar-se as configurações deste (Figura “Habilitando o encaminhamento de pacotes”).



```
FIREWALL IPTABLES

STATUS:
Interface LAN: 192.168.0.1
Interface WAN: 200.172.33.1
net.ipv4.ip_forward = 1

Opcoes
1. Carregar firewall
2. Descarregar firewall
3. Listar regras [FILTER]
4. Listar regras [NAT]
5. Exibir logs [SSH]
6. Exibir tabela de conexoes
*. Sair (teclar qqer outro valor)
```

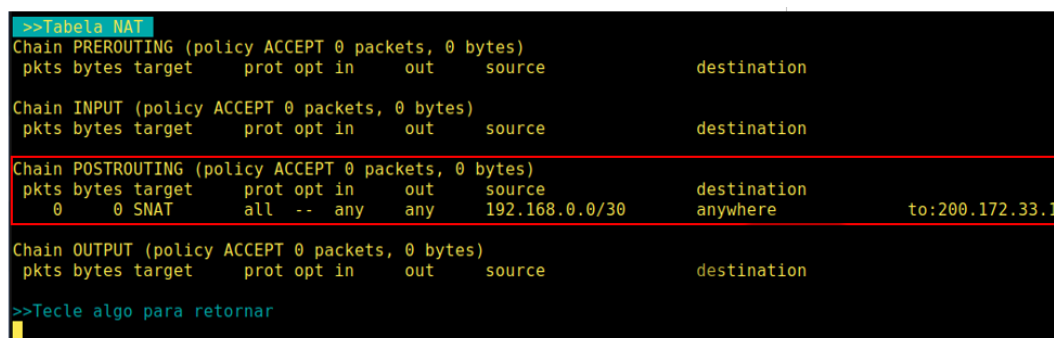
Figura 32 – Habilitando o encaminhamento de pacotes
Fonte: Elaborado pelo autor (2020)

Naturalmente, a habilitação do encaminhamento de pacotes no *kernel* constitui apenas uma das medidas necessárias ao devido funcionamento do *firewall*. Por meio da opção 4 deste, é possível observar que a tabela NAT também foi devidamente configurada a fim de atender às necessidades do cenário proposto, cabendo apontar aqui ser a função do *firewall* permitir que o *host* de testes possa:

- a. Testar a conectividade com o servidor (“ping”);
- b. Acessar o serviço HTTP do servidor;

- c. Acessar remotamente o console do servidor via SSH.

A Figura “Conteúdo da tabela NAT” ilustra o conteúdo da tabela NAT, após a carga das configurações do firewall.



```
>>Tabela NAT
Chain PREROUTING (policy ACCEPT 0 packets, 0 bytes)
pkts bytes target      prot opt in     out     source      destination
Chain INPUT (policy ACCEPT 0 packets, 0 bytes)
pkts bytes target      prot opt in     out     source      destination
Chain POSTROUTING (policy ACCEPT 0 packets, 0 bytes)
pkts bytes target      prot opt in     out     source      destination
0      0 SNAT        all  --  any    any    192.168.0.0/30  anywhere    to:200.172.33.1
Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
pkts bytes target      prot opt in     out     source      destination
>>Tecle algo para retornar
```

Figura 33 – Conteúdo da tabela NAT
Fonte: Elaborado pelo autor (2020)

No destaque da figura pode ser observado que a *chain POSTROUTING* “encapsula” os endereços IP originados no segmento de rede 192.168.0.0/30 (LAN) no único endereço IP público disponibilizado para o *firewall* (SNAT para o endereço IP 200.172.33.1), conforme determinado pela instrução destacada no Quadro “Configuração SNAT”.

```
# habilita SNAT sobre a interface publica
iptables -t nat -A POSTROUTING -s $lan -j SNAT --to $iWan
```

Comando de prompt 8 – Configuração SNAT
Fonte: Elaborado pelo autor (2020)

Cabe observar também, em relação à referida instrução, serem \$lan e \$WAN variáveis contendo, respectivamente, a faixa de endereços da rede local e o endereço IP da *interface* pública do firewall. Retornando-se agora à Figura “Conteúdo da tabela NAT”, observa-se que as políticas adotadas para todas as *chains* (*PREROUTING*, *INPUT*, *POSTROUTING*, *OUTPUT*) são permissivas (*ACCEPT*). A princípio, isto não seria incorreto?

Não, isto está correto! É necessário atentar ao fato que a tabela NAT não é destinada à filtragem de pacotes, por isso, o uso do *DROP* é inibido.

Na Figura “Conteúdo da tabela FILTER” é possível verificar que as regras definidas pelo script do firewall foram devidamente carregadas.

>>Tabela FILTER

Chain INPUT (policy DROP 0 packets, 0 bytes)									
pkts	bytes	target	prot	opt	in	out	source	destination	
0	0	ACCEPT	all	--	lo	any	anywhere	anywhere	
Chain FORWARD (policy DROP 0 packets, 0 bytes)									
pkts	bytes	target	prot	opt	in	out	source	destination	
7	420	ACCEPT	all	--	any	any	anywhere	anywhere	ctstate ESTABLISHED
1	60	ACCEPT	icmp	--	enp0s3	any	anywhere	anywhere	icmp echo-request
0	0	LOG	tcp	--	enp0s3	any	anywhere	anywhere	tcp dpt:ssh LOG level warning
prefix "SSH:"									
0	0	ACCEPT	tcp	--	enp0s3	any	anywhere	anywhere	multiport dports ssh,http
Chain OUTPUT (policy DROP 0 packets, 0 bytes)									
pkts	bytes	target	prot	opt	in	out	source	destination	
0	0	ACCEPT	all	--	any	lo	anywhere	anywhere	

>>Tecla algo para retornar

Figura 34 – Conteúdo da tabela FILTER
 Fonte: Elaborado pelo autor (2020)

Assim sendo, tem-se:

Políticas de acesso definidas de forma restritiva para todas as chains (destaque 1 da figura em referência);

A análise stateful do firewall foi devidamente configurada, permitindo assim o encaminhamento de requisições ao servidor (na rede externa), e o recebimento da respectiva resposta de forma adequada (destaque 2 da figura em referência);

Para fins de auditoria, as regras de acesso implementadas contemplam o log de todas as tentativas de acesso via SSH ao servidor remoto, tendo estas sucesso ou não (destaque 3 da figura em referência);

A utilização do parâmetro multiport (destaque 3 da figura em referência) auxilia na otimização das regras de acesso uma vez que os serviços SSH e HTTP foram adequadamente contemplados por regra única na chain FORWARD.

Como o sistema operacional Windows não provê recursos nativos para uso do serviço SSH, no cenário proposto foi utilizado o aplicativo Putty – disponível em <https://www.chiark.greenend.org.uk/~sgtatham/putty/latest.html>, para o teste do serviço. A Figura “Configuração do Putty” ilustra a configuração da referida ferramenta.

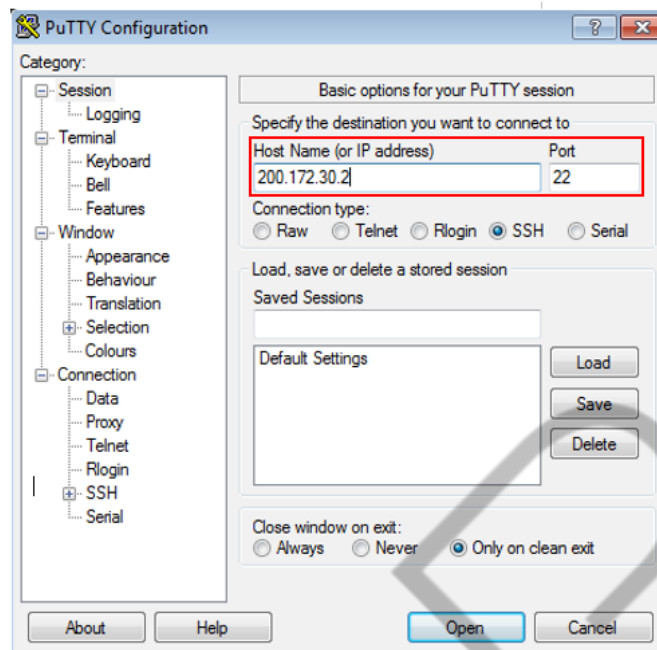


Figura 35 – Configuração do *Putty*
Fonte: Elaborado pelo autor (2020)

No destaque da figura, é necessário fornecer apenas o endereço IP do *host* de destino, uma vez que a porta a ser utilizada (padrão) já se encontra previamente configurada pelo aplicativo.

O destaque na Figura “Acesso remoto ao servidor” demonstra a configuração correta do serviço e o acesso remoto ao servidor de destino.

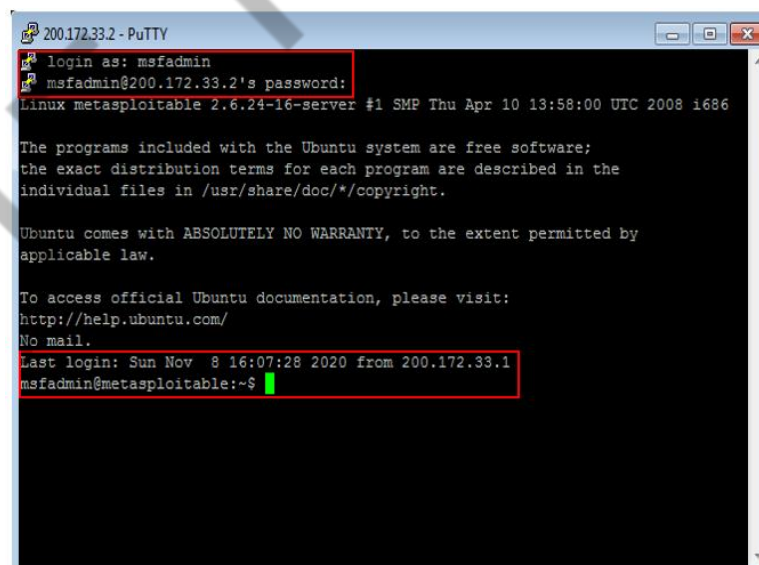


Figura 36 – Acesso remoto ao servidor
Fonte: Elaborado pelo autor (2020)

A partir da opção 6 no menu principal do *script*, é possível verificar a tabela de conexões do firewall.

```
>>Conntrack Table
ipv4      2 tcp      6 431888 ESTABLISHED src=192.168.0.2 dst=200.172.33.2 sport=49232 dport=22 src=200.172.33.2 dst=200.172.33.1 sport=22 dport=49232 [ASSURED] mark=0 zone=0 use=2
>>Tecle algo para retornar
```

Figura 37 – Conteúdo da tabela de conexões
Fonte: Elaborado pelo autor (2020)

A Figura “Tabela de conexões” registra os detalhes da conexão SSH originada pelo *host* local (192.168.0.2) para o servidor remoto (200.172.33.2). Por sua vez, a Figura “Log da conexão SSH” exibe o registro (*log*) da conexão SSH – opção 5 no menu principal do *firewall*.

```
>>Logs SSH
Nov 11 12:37:39 kraken kernel: [30868.056108] SSH:IN=enp0s3 OUT=enp0s8 MAC=08:00:27:be:b1:66:08:00:27:d5:ef:7c:08:00 SRC=192.168.0.2 DST=200.172.33.2 LEN=52 TOS=0x00 PREC=0x00 TTL=127 ID=8611 DF PROTO=TCP SPT=49232 DPT=22 WINDOW=8192 RES=0x00 SYN URG=0
>>Tecle algo para retornar
```

Figura 38 – Log da conexão SSH
Fonte: Elaborado pelo autor (2020)

Cabe reforçar, que os *logs* gerados pelo *host* devem ser armazenados em local adequado, preferencialmente fora deste, em um servidor de *logs*. Ampliando o exposto, vale a pena falar um pouco ainda sobre UTM's. Um UTM - *Unified Threat Management* (gerenciamento unificado de ameaças) é um termo que designa uma solução, ou *appliance*, de segurança únicos, porém, com múltiplas funcionalidades destinadas à segurança em um ponto específico da rede. Um UTM substituiria o firewall anteriormente criado com muitas vantagens ao centralizar diferentes funcionalidades em um único *appliance* ou *software*, dentre as quais elenca-se dentre as mais populares:

- Firewall
- Filtragem de de URL's e de conteúdo web
- Controle de aplicações
- *Proxies* (HTTP, DNS, e-mails etc.)

- VPN
- IPS
- Antivírus web
- Controle de usuários
- Anti-spam
- QoS (Quality of Service)

Para demonstrar de forma prática algumas das vantagens mais evidentes em relação à adoção de UTM's em substituição aos firewalls tradicionais será implementada uma nova VM, desta vez utilizando o *pfSense*, tradicional UTM de código aberto disponível sob diferentes formas. *Virtual appliances* com software *pfSense* estão disponíveis por meio dos serviços de nuvem *Amazon AWS* e *Microsoft Azure*, havendo também opção pela aquisição de um *appliance* físico. Por fim, há a opção de download do software para instalação em *hardware* não especializado.

A Figura “Opções *pfSense*” ilustra algumas das possibilidades para *deploy* do UTM.

	BEST USED FOR	PROCESSOR	RAM	STORAGE OPTIONS	PORTS	POWER	
 Cloud	Medium Business Large Business Growing Network	Virtualized	Virtualized	Virtualized	Virtualized		AMAZON AWS MICROSOFT AZURE
 SG-1100	Small Office Branch Office	ARM Cortex A53 1.2 GHz 2-Core	1GB DDR4	8GB eMMC Flash	3x 1GbE	3.48W (idle)	MORE DETAILS
 SG-2100	Small Office Branch Office Remote Worker	ARM Cortex A53 1.2 GHz 2-Core	4GB DDR4	8GB eMMC Flash	4x 1 GbE	4W (idle)	MORE DETAILS
 SG-3100	SOHO Network Remote Worker	ARMv7 Cortex-A9 1.6 GHz 2-Core	2GB DDR4	8GB eMMC Flash	6x 1GbE	6W (idle)	MORE DETAILS
 SG-5100	Medium Business SMB Network Gigabit Speeds	Intel Atom® 2.2 GHz 4-Core	4GB DDR4	8GB eMMC Flash	6x Intel 1GbE	7W (idle)	MORE DETAILS
 XG-7100	Medium Business Large Business Gigabit and 10 Gigabit Speeds	Intel Atom® 2.2 GHz 4-Core	8GB DDR4	32GB eMMC Flash 256GB M.2 SATA SSD	2x Intel 10Gb SFP+ 8x Intel 1GbE	20W (idle)	MORE DETAILS

Figura 39 – Opções *pfSense*
Fonte: Elaborado pelo autor (2020)

Para efeito de implementação do cenário proposto, deverá ser criada uma nova a partir da ISO do UTM disponível em <https://www.pfsense.org/download/> . Na página de *download*, selecionar arquitetura AMD64(64Bits) e instalador CD IMAGE (ISO).

Atenção: a imagem baixada estará compactada pelo *gzip*. Portanto, antes de iniciar a criação da VM esta deverá ser descompactada. No *Linux*, o próprio *gzip* poderá ser utilizado, já no Windows – dentre outros, o 7Zip poderá ser empregado.

O Quadro “Propriedades da VM *pfSense*” exibe as configurações propostas para a nova VM.

Parâmetro		Valor
Nome		pfSense
Tipo		BSD
Versão		FreeBSD (64bit)
Memória RAM		1GB
Disco virtual		VDI/10GB
vCPU		1
Rede	Adaptador 1	Bridge - WAN
	Adaptador 2	Rede Interna - LAN

Quadro 6 – Propriedades da VM *pfSense*

Fonte: Elaborado pelo autor (2020)

A instalação do *pfSense* é extremamente simples e rápida e deverá ser feita **aceitando-se todas as opções padrão oferecidas**, não esquecendo de ejetar a mídia de instalação virtual durante o processo de *reboot* do *host*. Para tal, basta acessar a opção “Dispositivos” do menu principal, escolhendo em sequência a opção “Discos Ópticos” e finalmente “Remover disco do drive virtual” (destaque superior Figura “Instalação do *pfSense*”).

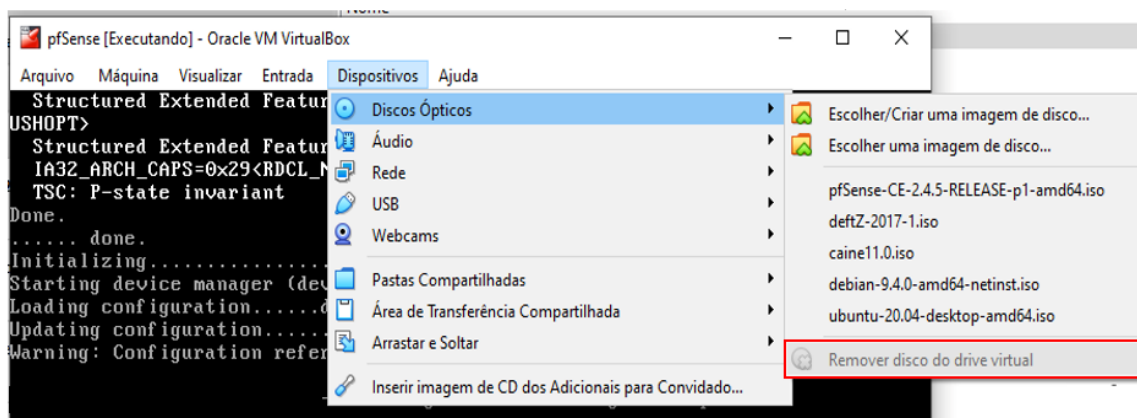


Figura 40 – Instalação do *pfSense*
Fonte: Elaborado pelo autor (2020)

Finalizado o processo de instalação do *pfSense*, a VM cliente (*Windows 7*) deverá ter sua *interface* de rede reconfigurada para DHCP.

ATENÇÃO: Certifique-se que a faixa de endereços fornecida pelo *pfSense* para a LAN virtual (192.168.1.1), onde residirá VM de cliente, não conflita com a faixa da rede LAN real, a qual simulará a Internet.

A Figura “Topologia de referência 3 – *pfSense*” ilustra o novo cenário a ser desenvolvido.

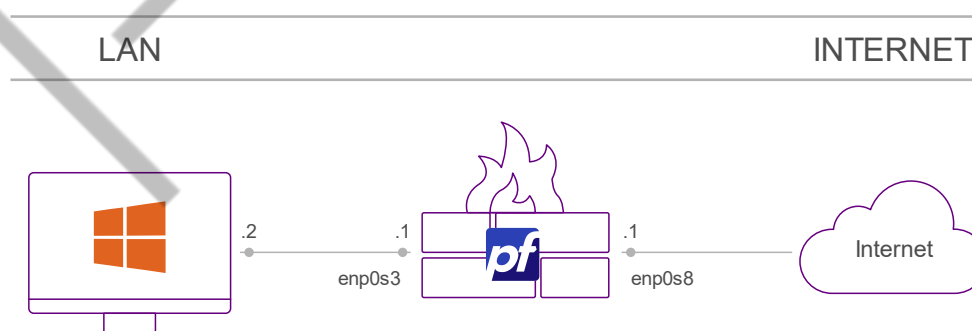


Figura 41 – Topologia de referência 3 – *pfSense*
Fonte: Elaborado pelo autor (2020)

Tendo o cenário da Figura “Topologia de referência 3 – *pfSense*” devidamente e operacional, o console do *pfSense* se assemelhará ao ilustrado pela Figura “Console do *pfSense*”.

```
pfSense 2.4.5-RELEASE (Patch 1) amd64 Tue Jun 02 17:51:17 EDT 2020
Bootup complete

FreeBSD/amd64 (pfSense.localdomain) (ttyv0)

VirtualBox Virtual Machine - Netgate Device ID: b42dc60161c5f29eadf3

*** Welcome to pfSense 2.4.5-RELEASE-p1 (amd64) on pfSense ***

WAN (wan)      -> em0      -> v4/DHCP4: 192.168.16.5/24
                v6/DHCP6: 2804:14c:122:2225:a00:27ff:fe18:b437
/64
LAN (lan)      -> em1      -> v4: 192.168.1.1/24

0) Logout (SSH only)          9) pfTop
1) Assign Interfaces          10) Filter Logs
2) Set interface(s) IP address 11) Restart webConfigurator
3) Reset webConfigurator password 12) PHP shell + pfSense tools
4) Reset to factory defaults  13) Update from console
5) Reboot system              14) Enable Secure Shell (sshd)
6) Halt system                 15) Restore recent configuration
7) Ping host                   16) Restart PHP-FPM
8) Shell

Enter an option: 
```

Figura 42 – Console do *pfSense*
Fonte: Elaborado pelo autor (2020)

Os destaques na referida figura apontam para os endereços IP atribuídos às interfaces WAN e LAN. A interface gráfica para configuração do *pfSense* poderá, então, ser acessada digitando o endereço IP da interface LAN deste no navegador da VM cliente (*Windows 7*), conforme ilustrado pela Figura “Interface gráfica de configuração”.

As credenciais para acesso às configurações são: *username* admin e *password* pfsense.

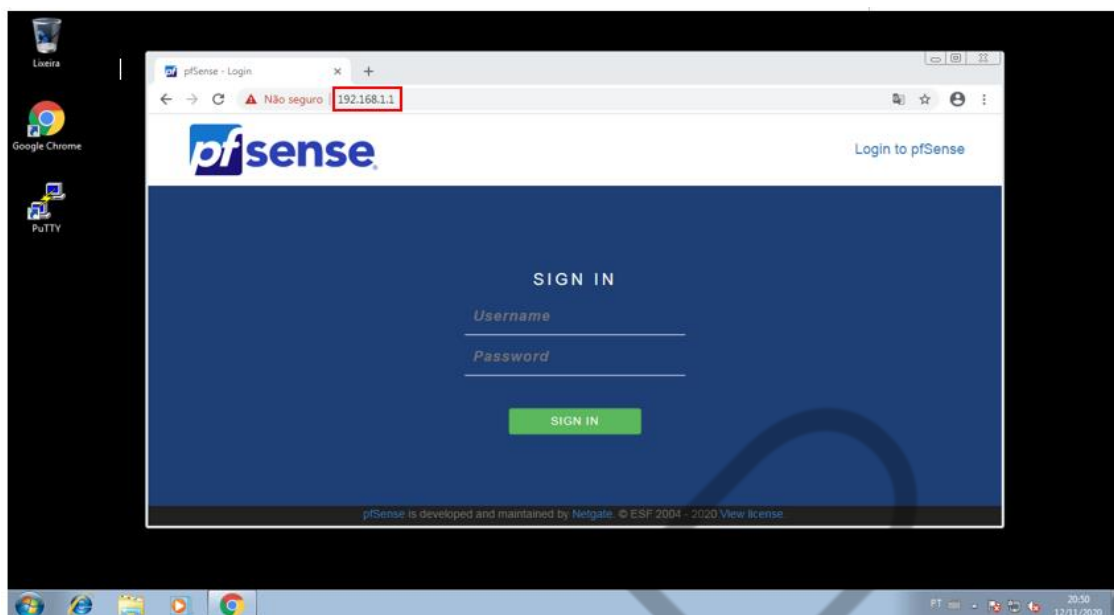


Figura 43 – Interface gráfica de configuração
Fonte: Elaborado pelo autor (2020)

O primeiro acesso à interface gráfica do pfSense ativa o wizard para configuração básica deste o qual, entretanto, poderá ser ignorado clicando diretamente sobre o nome do UTM no canto superior esquerdo da janela. Na sequência, fechando também as janelas que surgirão, aparecerá ao dashboard do UTM (Figura “Dashboard do pfSense”).

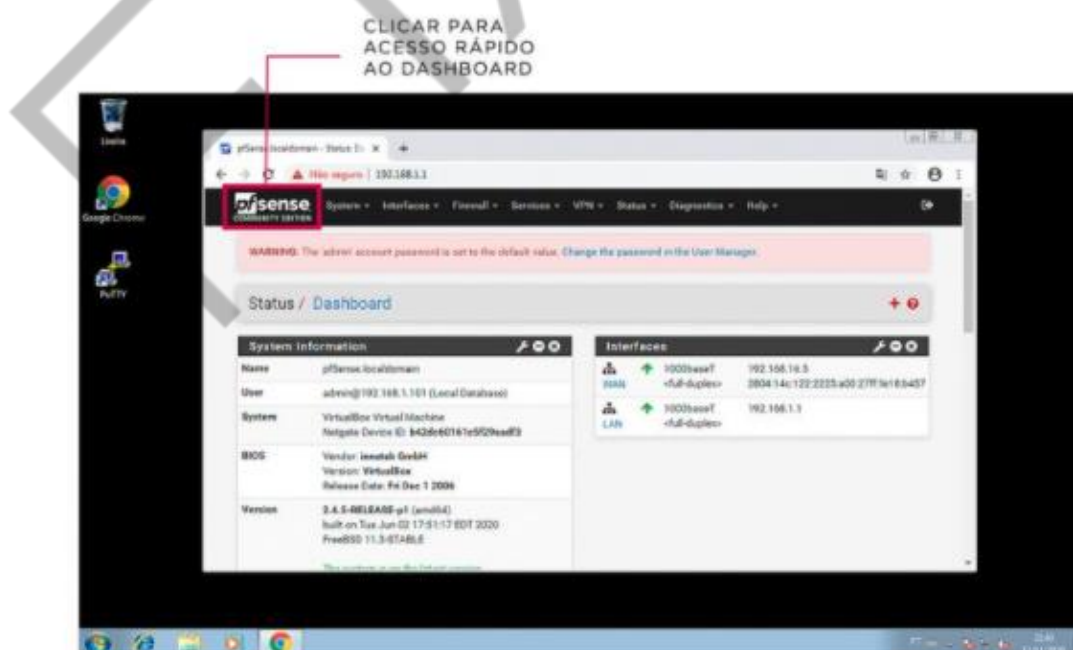


Figura 44 – Dashboard do pfSense
Fonte: Elaborado pelo autor (2020)

Tendo em vista que o objetivo desta prática não é a configuração do UTM, mas sim, demonstrar a diferença entre este tipo de dispositivo e um firewall tradicional, os trabalhos serão iniciados analisando as regras padrão implementadas por este. Para tal, basta a partir da opção FIREWALL no menu principal, clicar em *RULES*. A Figura “Regras padrão - WAN” ilustra as regras configuradas por padrão para a *interface* WAN.

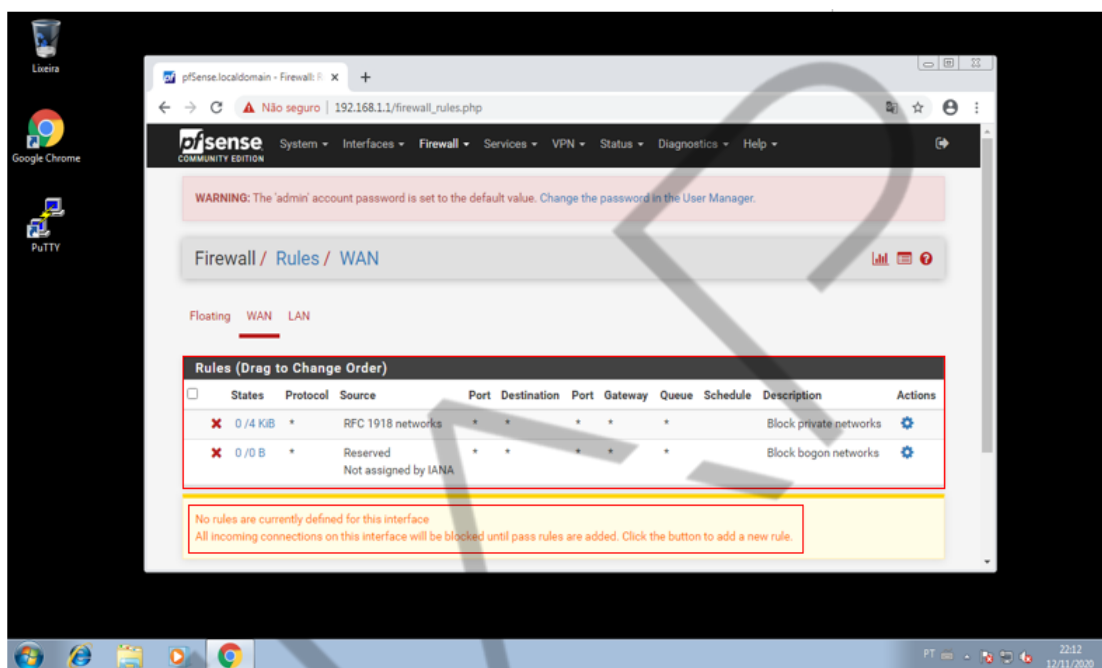


Figura 45 – Regras padrão – WAN
Fonte: Elaborado pelo autor (2020)

A primeira regra padrão configurada no UTM (destaque superior da figura em referência – *Block private networks*) determina que todo tráfego originado por endereços IP definidos pela RFC 1918 como privativos (10/8, 172.16/12, 192.168/16) seja bloqueado. Embora não seja possível verificar unicamente por meio da referida figura, tal regra estende sua ação também a endereços locais exclusivos – conforme RFC4193, e endereços de *loopback* (127/8). Salvo casos específicos como, por exemplo, quando esta *interface* também reside em espaço de endereçamento privativo, esta regra é mantida habilitada.

A segunda regra configurada por padrão no UTM (*Block bogon networks*) bloqueia tráfego de endereços IP reservados – não contemplados pela RFC 1918, ou ainda não atribuídos pela IANA. *Bogons* são prefixos que nunca devem aparecer na tabela de roteamento da *Internet* e, assim sendo, também não devem figurar como o endereço de origem em nenhum pacote recebido. Vale ressaltar ainda, com base no destaque inferior da Figura “Regras padrão – WAN” que, como nenhuma regra específica foi configurada para esta *interface*, todas as conexões *inbound* serão bloqueadas, demonstrando a política restritiva adotada pelo UTM. A Figura “Regras padrão – LAN” ilustra as regras padrão configuradas no UTM para a *interface* LAN.

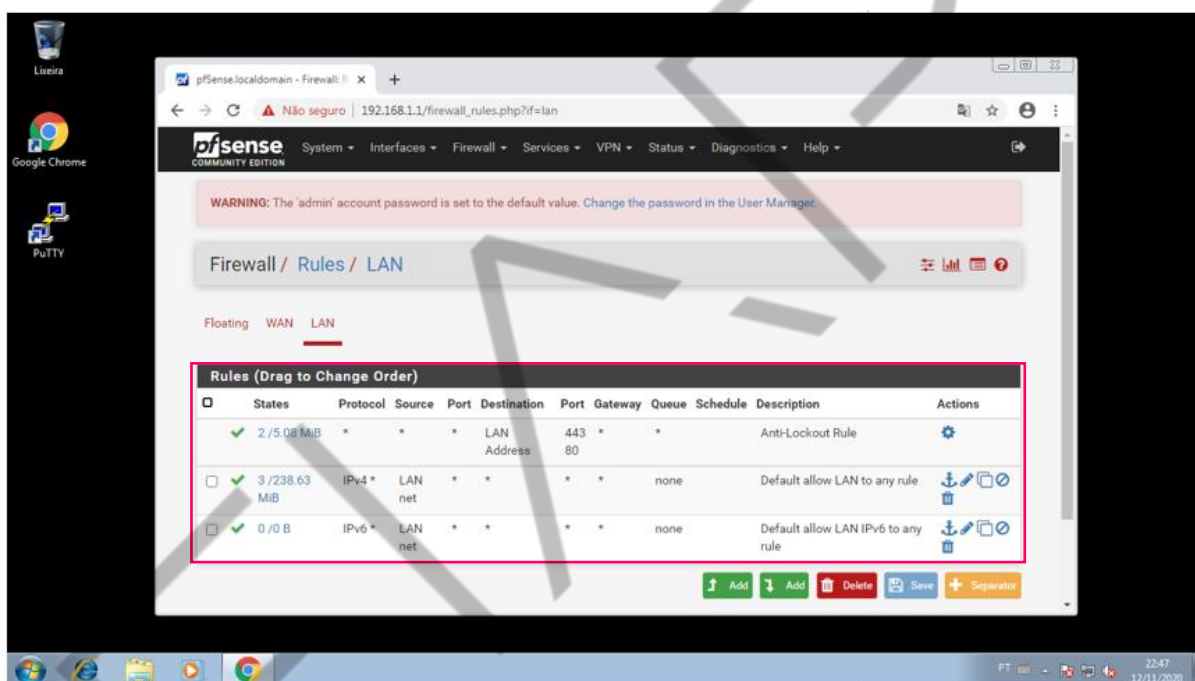


Figura 46 – Regras padrão – LAN
Fonte: Elaborado pelo autor (2020)

A primeira regra no destaque da Figura “Regras padrão – LAN” – *Anti-Lockout Rule*, libera o tráfego de qualquer protocolo que chega a esta *interface* com destino às portas 80 e 443 da *interface* do UTM conectada à LAN (*LAN address*) tendo, portanto, como finalidade garantir o acesso à *interface web* de configuração do UTM. Certamente, esta regra deveria ser ajustada quando da efetiva configuração do UTM de forma a restringir o acesso concedido apenas às *hosts* ou *sub-redes* específicas. As duas regras subsequentes na mesma figura liberam o tráfego originado por qualquer protocolo IPv4 ou IPv6, originados na rede local (*LAN net*), independentemente de seu destino.

Logo, tais regras também deverão ser devidamente ajustadas quando da efetiva configuração do UTM a fim de promover a devida filtragem e restringir o tráfego apenas aos protocolos desejados. Ao abrir uma nova aba no navegador é possível verificar que os serviços *web* estão disponíveis sem restrições, permitindo a navegação para qualquer *web site*, *download* de arquivos e acesso à vídeos e músicas, dentre outros serviços (Figura “Teste de navegação”).

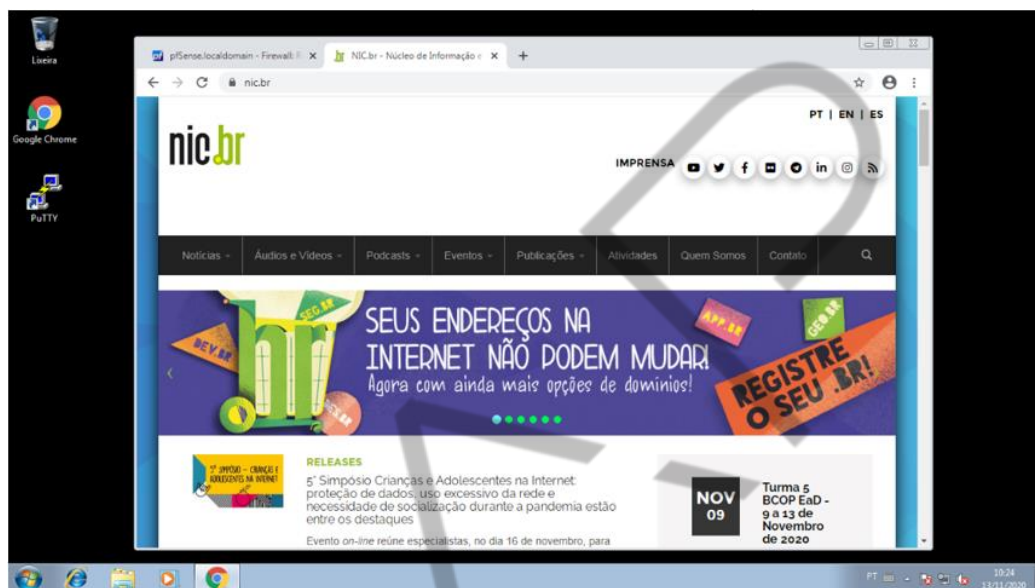


Figura 47 – Teste de navegação
Fonte: Elaborado pelo autor (2020)

Conforme citado anteriormente, além do compartilhamento do acesso à *Internet*, os UTM's dispõem de muitas outras funcionalidades não contempladas pelos firewalls tradicionais. A lista disponibilizada pela opção “*Services*” no menu principal da *interface* gráfica exibe os serviços disponibilizados por padrão pelo *pfSense* (Figura “Opções do menu *Services*”).

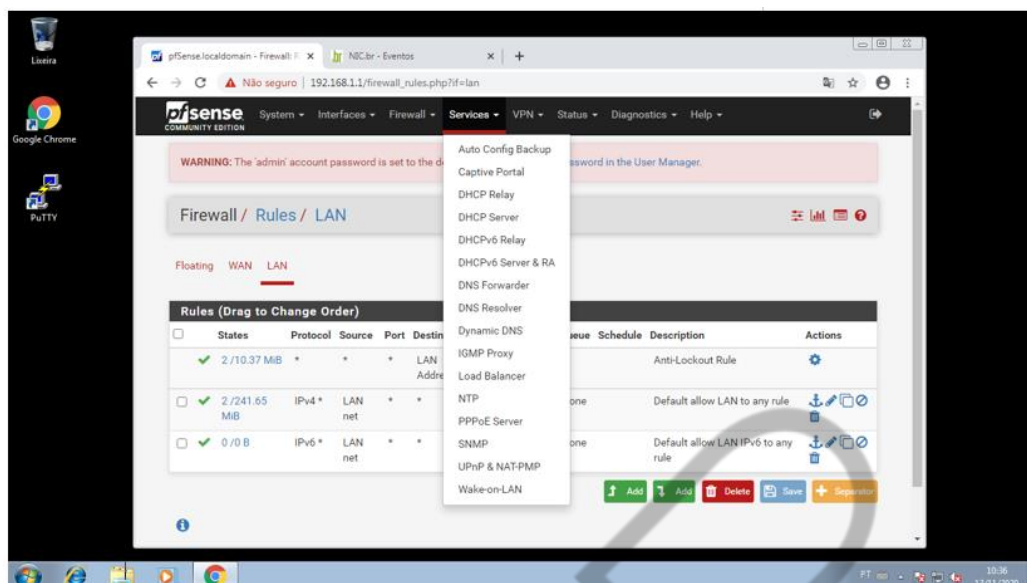


Figura 48 – Opções do menu *Services*
Fonte: Elaborado pelo autor (2020)

Na Figura “Opções do menu *Services*” podemos destacar alguns serviços disponibilizados pelo UTM, tais como:

- **Captive Portal:** funcionalidade que promove a segregação entre os segmentos cabeados e *Wi-Fi* da rede local, podendo, ainda, melhorar significativamente a forma de autenticação dos usuários;
- **DNS Resolver:** funcionalidade que permite ao UTM atuar como servidor DNS interno em redes que ainda não disponham de um;
- **DNS Forwarder:** funcionalidade que resolve as consultas DNS externas encaminhadas pelos servidores DNS internos, evitando, assim, que estes venham a se expor à rede não confiável (*Internet*);
- **Load Balancer:** funcionalidade destinada à alta disponibilidade de serviço ou aumento de capacidade, por exemplo, na forma de redundância de *links* WAN.

No menu principal da interface gráfica é possível observar a disponibilidade do serviço VPN, o qual oferece três diferentes modelos: IPsec, L2TP, *OpenVPN* (Figura “Serviço VPN”).

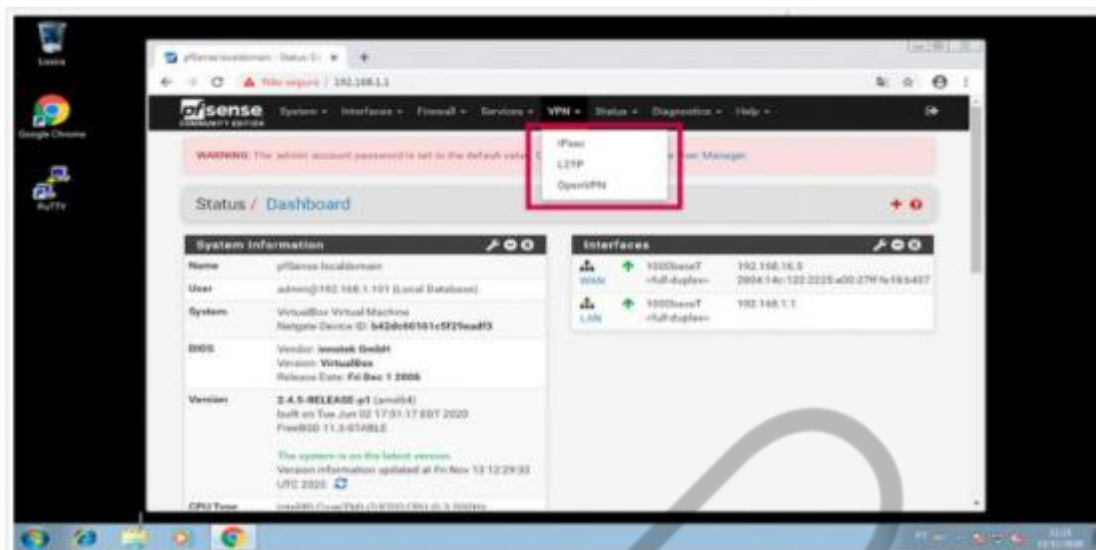


Figura 49 – Serviço VPN
Fonte: Elaborado pelo autor (2020)

Além disso, outros serviços não disponibilizados por padrão pelo *pfSense* poderão ser instalados via repositório, por meio do gerenciador de pacotes do UTM, conforme ilustrado parcialmente na Figura “Exemplos de pacotes adicionais”.

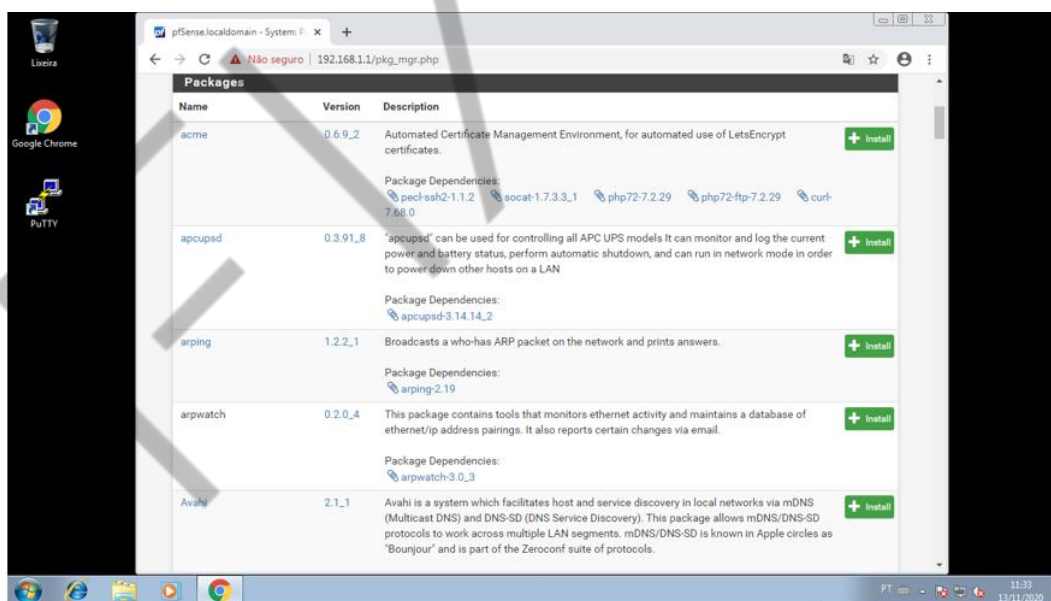


Figura 50 – Exemplos de pacotes adicionais
Fonte: Elaborado pelo autor (2020)

REFERÊNCIAS

AYUSO, P. N. **Netfilter's connection tracking system**. [s.d.]. Disponível em: <<http://people.netfilter.org/pablo/docs/login.pdf>>. Acesso em: 4 mar. 2021.

CISCO. **O que é um firewall**. [s.d.]. Disponível em: <https://www.cisco.com/c/pt_br/products/security/firewalls/what-is-a-firewall.html>. Acesso em: 4 mar. 2021.

FIREWALLBUILDER. [s.d.]. Disponível em: <<http://fwbuilder.sourceforge.net/index.shtml>>. Acesso em: 4 mar. 2021.

GUIA Foca Linux. Capítulo 10 – **Firewall IPTables**. [s.d.]. Disponível em <<https://www.ppgia.pucpr.br/pt/arquivos/techdocs/linux/foca-avancado/ch-fw-iptables.html#s-fw-iptables-nat-fastmasquerade>>. Acesso em: 4 mar. 2021.

NETFILTER. **IPTables project**. [s.d.]a. Disponível em: <<https://netfilter.org/projects/iptables/index.html>>. Acesso em: 4 mar. 2021.

NETFILTER. **The conntrack-tools user manual**. [s.d.]a. Disponível em: <<http://conntrack-tools.netfilter.org/manual.html>>. Acesso em: 4 mar. 2021.

PFSENSE. [s.d.]. Disponível em <<https://www.pfsense.org>>.

RASH, M. **Linux Firewalls Attack Detection and Response with IPTABLES, PSAD and FWSNORT**. San Francisco, CA.: No Starch Press, Inc. 2007.

RED HAT. **Forward and NAT rules**. [s.d.]b. Disponível em: <https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/4/html/security_guide/s1-firewall-ipt-fwd>. Acesso em: 4 mar. 2021.

RED HAT. **IPTables And Connection Tracking**. [s.d.]a. Disponível em: <https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/6/html/security_guide/sect-security_guide-firewalls-iptables_and_connection_tracking>. Acesso em: 4 mar. 2021.